



# CCS6214

Lecture 7

Network Security





# Topics

1. Networking Fundamentals
2. Network Threats
  1. Passive Network Attacks
  2. Active Network Attacks
3. Mitigating Network Attacks
  1. Firewall
  2. Intrusion Detection System (IDS)
  3. Virtual Private Network (VPN)
  4. IPSec



# Network Fundamentals

Part 1

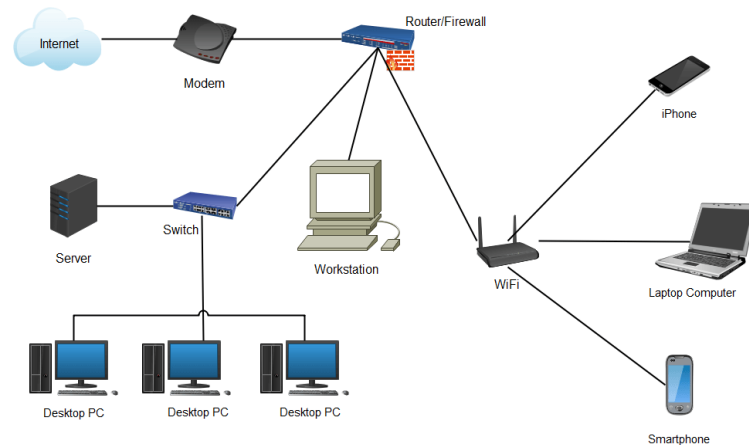


# What is networking?

- A network is simply two or more computers linked together to share data, information or resources.
- To properly establish secure data communications, it is important to explore all of the technologies involved in computer communications.
- From hardware and software to protocols and encryption and beyond, there are many details, standards and procedures to be familiar with

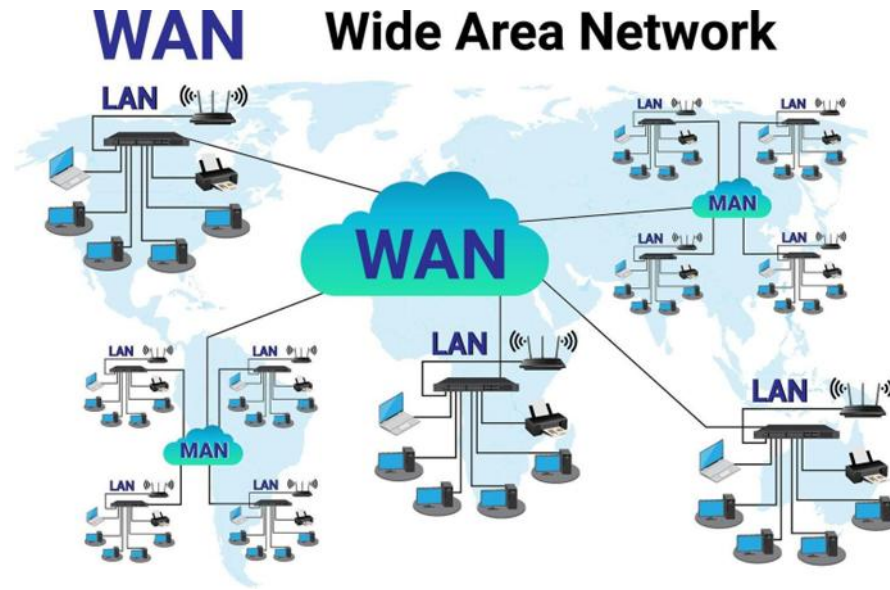
# Type of Network

- Local area network (LAN) - A local area network (LAN) is a network typically spanning a single floor or building. This is commonly a limited geographical area.
- The simplest form of LAN is to connect two computers together.



# Type of Network

- Wide area network (WAN) - Wide area network (WAN) is the term usually assigned to the long-distance connections between geographically remote networks.





# Network Devices

- Hubs are used to connect multiple devices in a network. They're less likely to be seen in business or corporate networks than in home networks. Hubs are wired devices and are not as smart as switches or routers. You might consider using a switch, or what is also known as an intelligent hub.
- Switches are wired devices that know the addresses of the devices connected to them and route traffic to that port/device rather than retransmitting to all devices. Offering greater efficiency for traffic delivery and improving the overall throughput of data, switches are smarter than hubs, but not as smart as routers. Switches can also create separate broadcast domains when used to create VLANs.
- Routers are used to control traffic flow on networks and are often used to connect similar networks and control traffic flow between them. Routers can be wired or wireless and can connect multiple switches. Smarter than hubs and switches, routers determine the most efficient "route" for the traffic to flow across the network.



# Network Devices

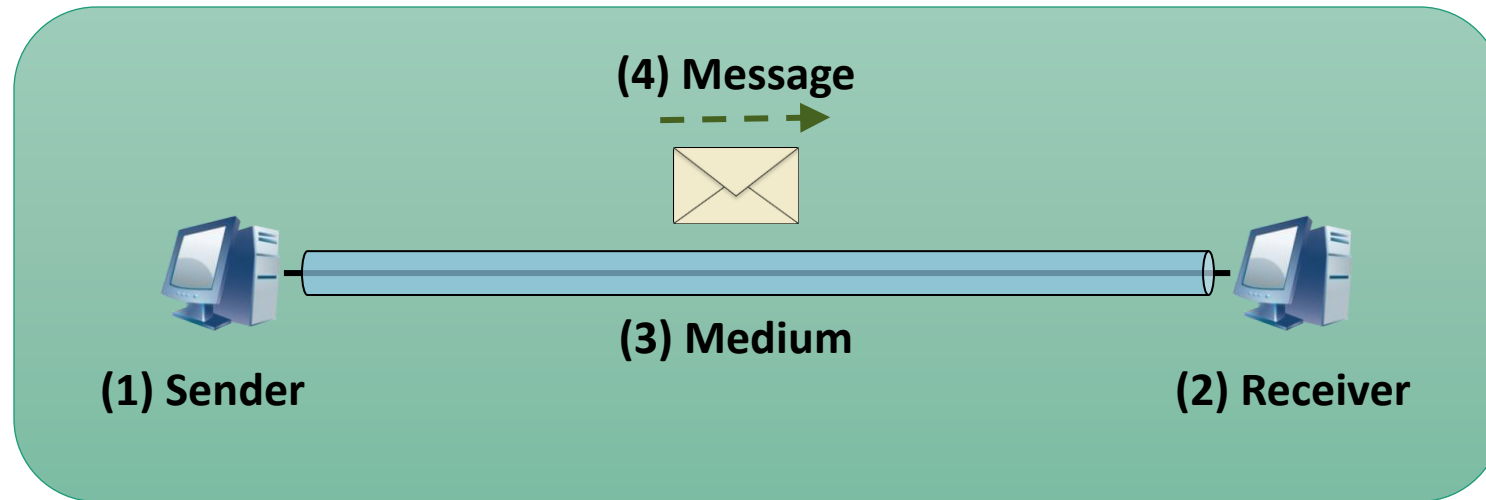
- **Firewalls** are essential tools in managing and controlling network traffic and protecting the network. A firewall is a network device used to filter traffic. It is typically deployed between a private network and the internet, but it can also be deployed between departments (segmented networks) within an organization (overall network). Firewalls filter traffic based on a defined set of rules, also called filters or access control lists.
- **Server** is a computer that provides information to other computers on a network. Some common servers are web servers, email servers, print servers, database servers and file servers. All of these are, by design, networked and accessed in some way by a client computer. Servers are usually secured differently than workstations to protect the information they contain.
- **Endpoints** are the ends of a network communication link. One end is often at a server where a resource resides, and the other end is often a client making a request to use a network resource. An endpoint can be another server, desktop workstation, laptop, tablet, mobile phone or any other end user device.



# Other Networking Terms

- Ethernet (IEEE 802.3) is a standard that defines wired connections of networked devices. This standard defines the way data is formatted over the wire to ensure disparate devices can communicate over the same cables.
- Media Access Control (MAC) Address - Every network device is assigned a Media Access Control (MAC) address. An example is 00-13-02-1F-58-F5. The first 3 bytes (24 bits) of the address denote the vendor or manufacturer of the physical network interface. No two devices can have the same MAC address in the same local network; otherwise,
  - an address conflict occurs.
- Internet Protocol (IP) Address - While MAC addresses are generally assigned in the firmware of the interface, IP hosts associate that address with a unique logical address. This logical IP address represents the network interface within the network and can be useful to maintain communications when a physical device is swapped with new hardware. Examples are 192.168.1.1 and 2001:db8::ffff:0:1.

# Components of Data Communications

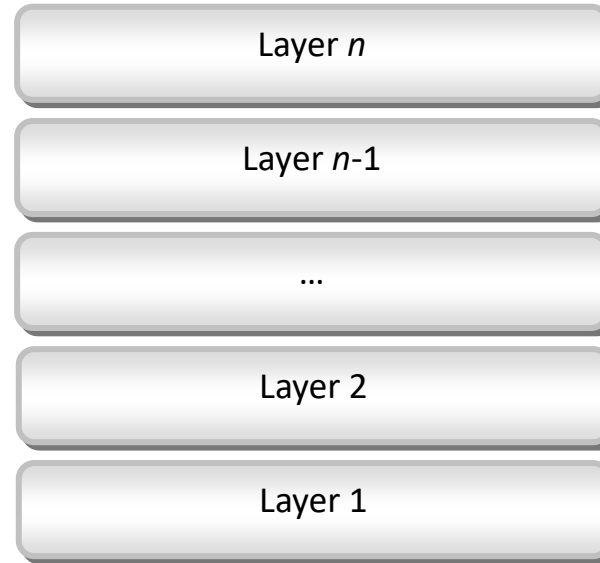


Communication is governed by **(5) Protocol**

Each component is an avenue for attacks

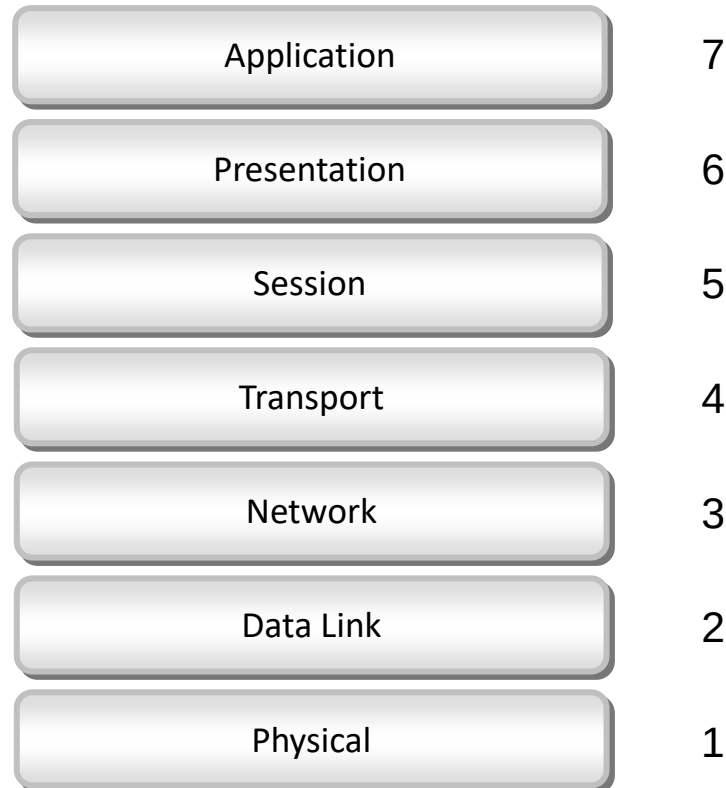
- **Sender & Receiver** – Phishing, social engineering, malware
- **Medium** – Eavesdropping, evil twin access point
- **Message** – Man-in-the-middle, SQL injection
- **Protocol** – DDoS, DNS poisoning

# Layered Network Model



- The layered network model divides the enormous, varied, and complex communication process into smaller tasks or layers
- Two network models:
  - OSI Network Model
  - TCP/IP Network Model

# OSI Network Model

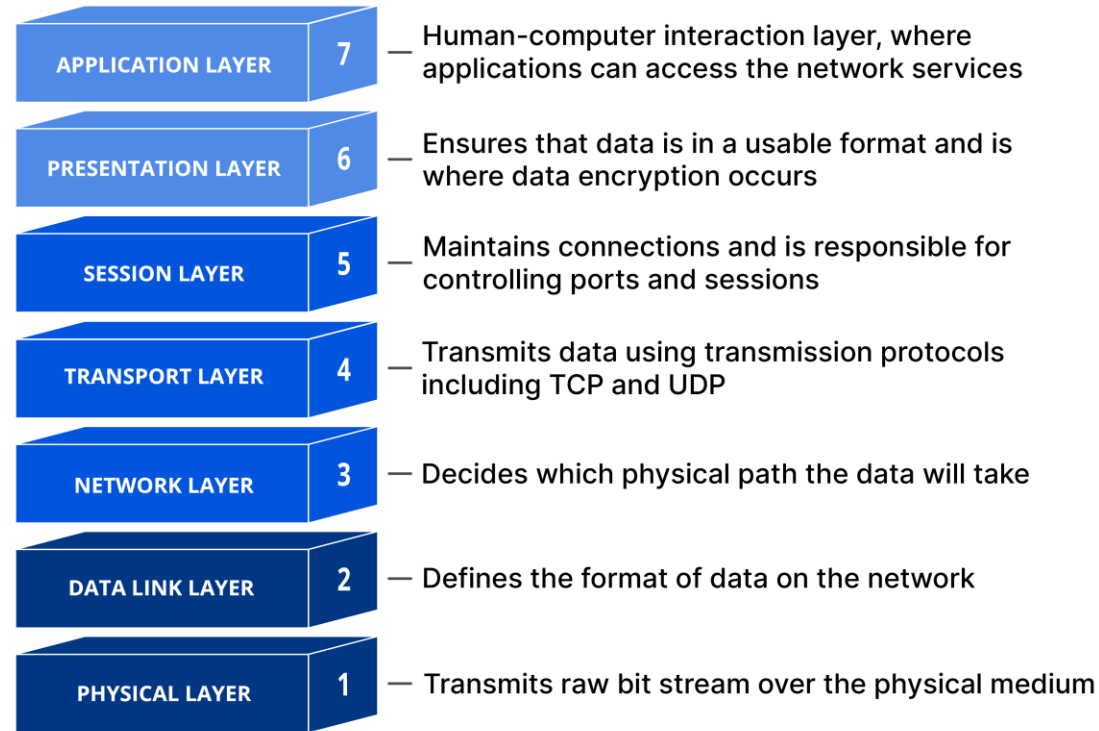


- Open System Interconnection (OSI) Network Model by International Standards Organisation (ISO)
- Consists of **7 layers**

# Functions of OSI Layers

|              |   |                                                                                       |
|--------------|---|---------------------------------------------------------------------------------------|
| Application  | 7 | Allow access to network resources                                                     |
| Presentation | 6 | Translate, compress, and encrypt data                                                 |
| Session      | 5 | Establish, manage, and terminate session                                              |
| Transport    | 4 | Provide end-to-end message delivery                                                   |
| Network      | 3 | Addressing and routing                                                                |
| Data Link    | 2 | Provide link medium access and link management                                        |
| Physical     | 1 | Provide mechanical and electrical specification;<br>transfer data in the form of bits |

# Open Systems Interconnection (OSI) Model

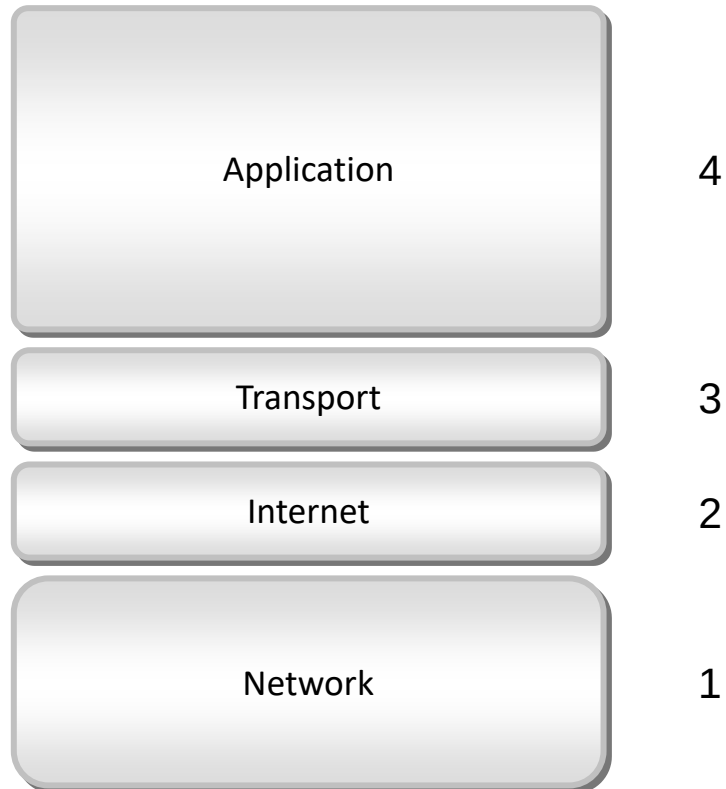


<https://www.youtube.com/watch?v=qBXmbJZQ5rY>

<https://www.youtube.com/watch?v=xiGgrQioF2E>

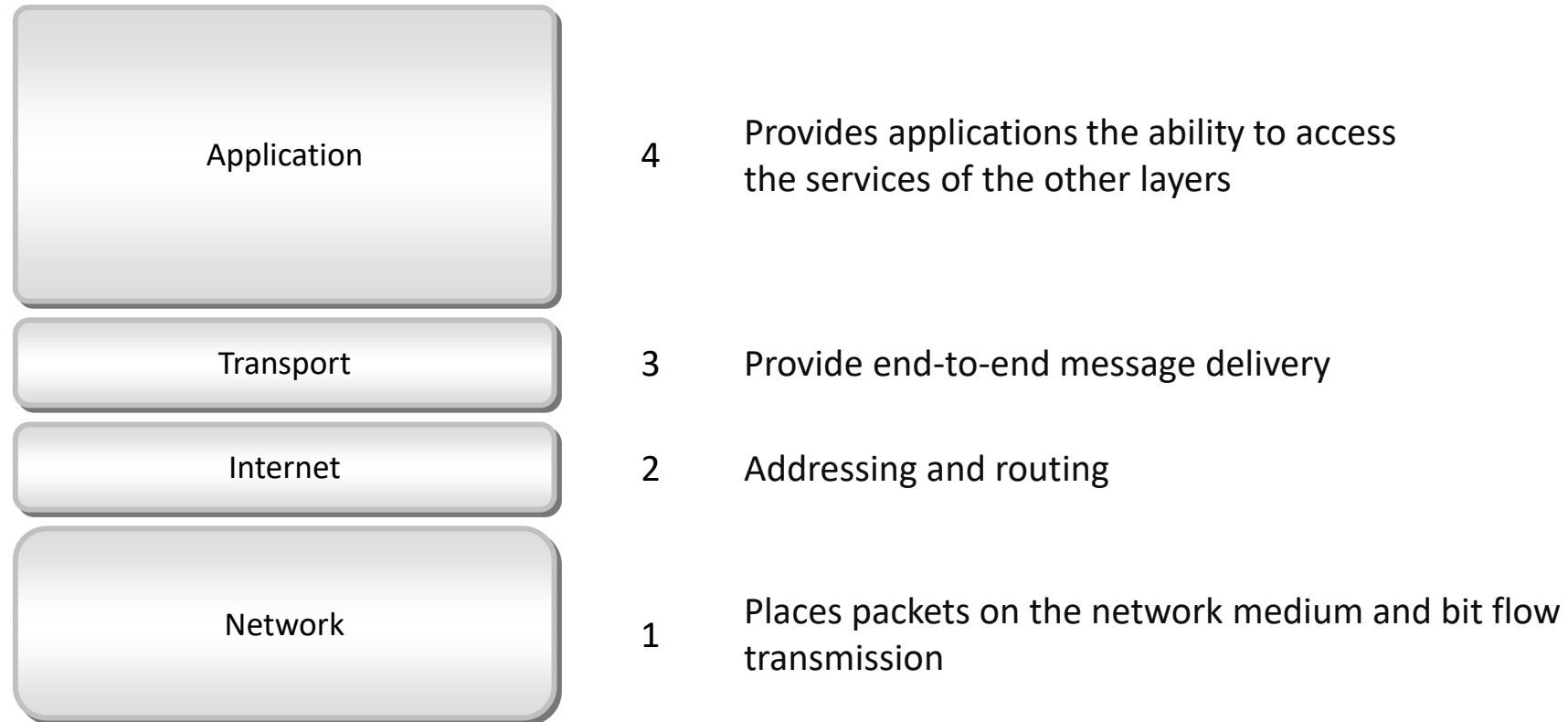
<https://www.youtube.com/watch?v=oQzueBVyAM4>

# TCP/IP Network Model

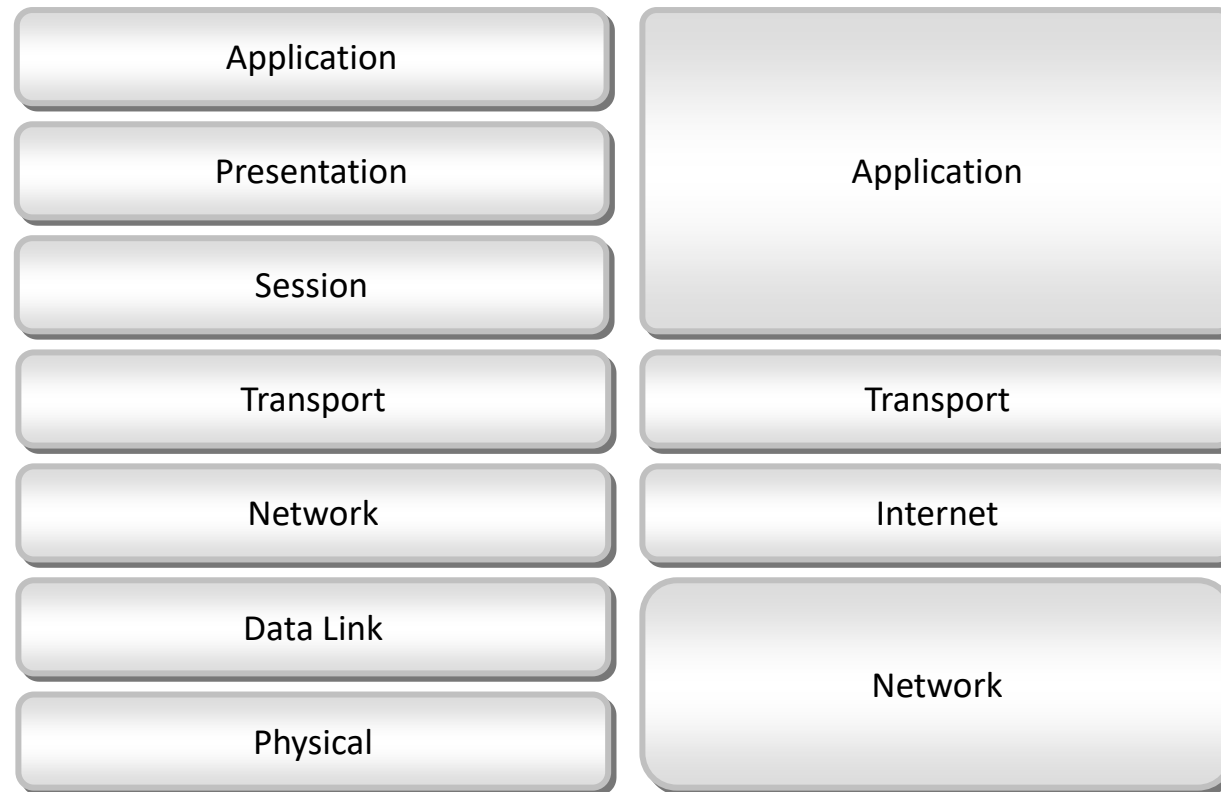


- Transmission Control Protocol and Internet Protocol (TCP/IP)
- Simpler with less layers but still functionally similar
- Consists of **4 layers**

# Functions of TCP/IP Layers



# OSI vs TCP/IP



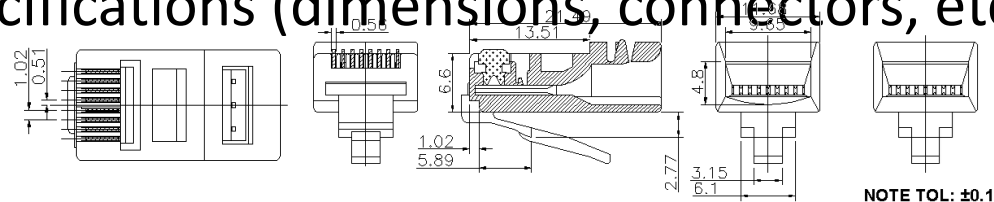
# TCP/IP Protocol

| OSI Model Layers   | TCP/IP Protocol Architecture | TCP/IP Protocol Suite |               |            |          |
|--------------------|------------------------------|-----------------------|---------------|------------|----------|
| Application Layer  | Application Layer            | FTP                   | Telnet        | SNMP       | LPD      |
| Presentation Layer |                              | TFTP                  | SMTP          | NFS        | X Window |
| Session Layer      |                              |                       |               |            |          |
| Transport Layer    | Transport Layer              | TCP                   |               | UDP        |          |
| Network Layer      | Internet Layer               | IGMP                  | IP            |            | ICMP     |
| Data Link Layer    | Network Interface Layer      | Ethernet              | Fast Ethernet | Token Ring | FDDI     |
| Physical Layer     |                              |                       |               |            |          |

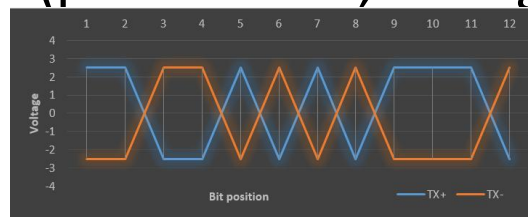


# OSI Layer 1 – Physical Layer

- Physical Layer defines:
  - Mechanical specifications (dimensions, connectors, etc.)



- Electrical specifications (power level, voltage, etc.)



- Operational and functional specifications (data rates, max distance, etc.)

# OSI Layer 1 – Physical Layer – *Cont.*

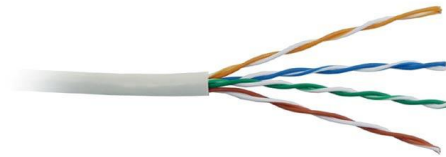
- Physical Layer also defines the medium



Coaxial Cable



Electromagnetic Waves



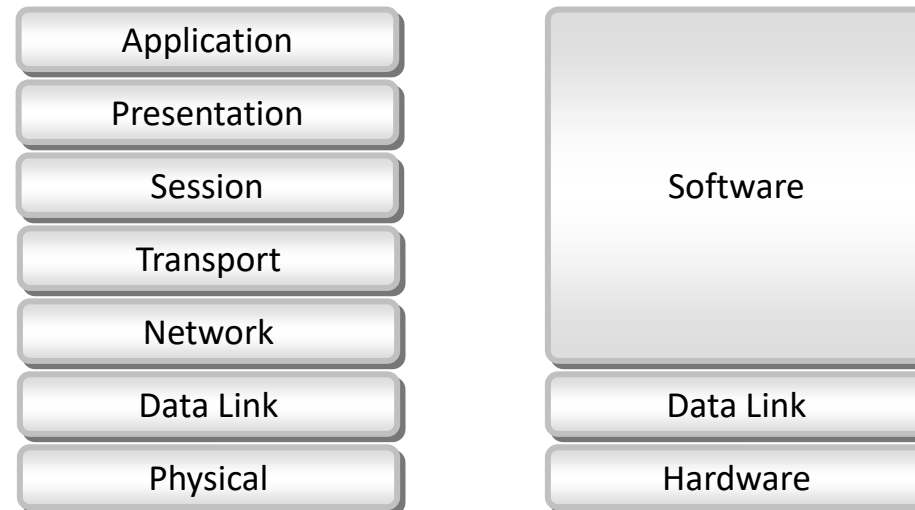
Twisted Pair Cable



Fiber Optic

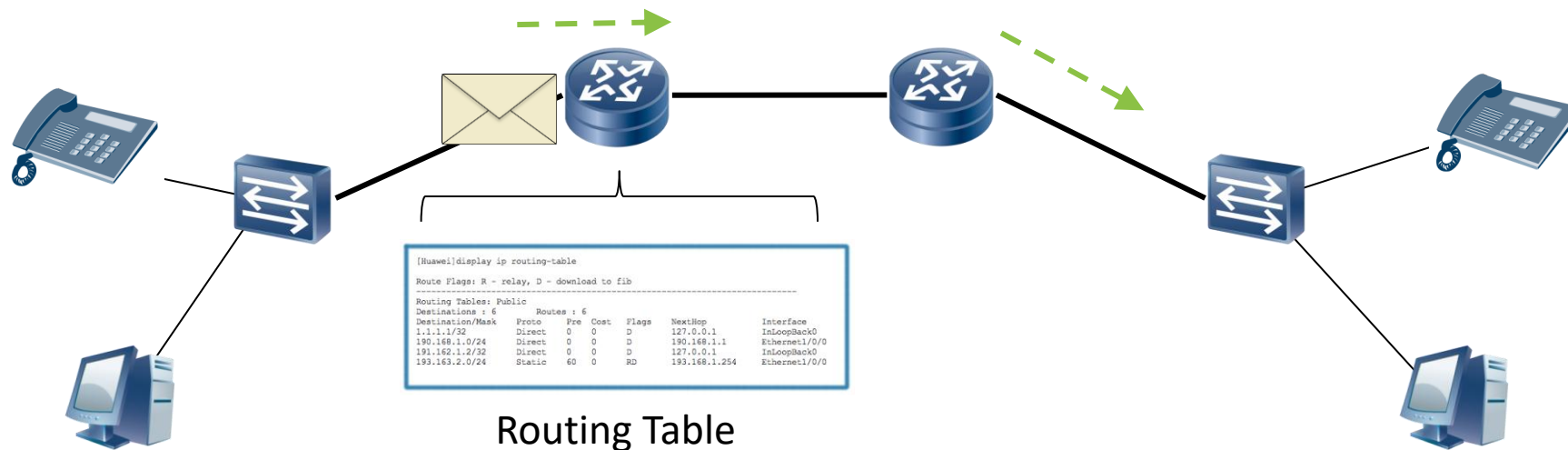
# OSI Layer 2 – Data Link Layer

- Organises bits into frames and deliver frames over a network link
- Generally, functions as a intermediary layer between hardware and software layers



# OSI Layer 3 – Network Layer

- Provides end-to-end message delivery using:
  - Network layer addressing (i.e. IP address)
  - Routing and forwarding





# IPV4 and IPV6

- IPv4 provides a 32-bit address space. IPv6 provides a 128-bit address space. IPV4 is exhausted nowadays, but it is still used because of the NAT technology. 32 bits means 4 octets of 8 bits, which is represented in a dotted decimal notation such as 192.168.0.1, which means in binary notation 11000000 10101000 00000000 00000001
- An IPv6 address is shown as 8 groups of four digits. Instead of numeric (0-9) digits like IPv4, IPv6 addresses use the hexadecimal range (0000-ffff) and are separated by colons (:) rather than periods (.).
- An example IPv6 address is 2001:0db8:0000:0000:0000:ffff:0000:0001. To make it easier for humans to read and type, it can be shortened by removing the leading zeros at the beginning of each field and substituting two colons (::) for the longest consecutive zero fields. All fields must retain at least one digit. After shortening, the example address above is rendered as 2001:db8::ffff:0:1, which is much easier to type.



# OSI Layer 4 – Transport Layer

- Provides transparent end-to-end transfer of data between processes/software:
  - Sets up end-to-end connection
  - Split the data into smaller segments (if necessary)
  - Ensure reliability of data transmission
- Two protocols in transport layer:
  - Transmission Control Protocol (TCP)
  - User Datagram Protocol (UDP)

# OSI Layer 4 – Transport Layer Protocols

## TCP

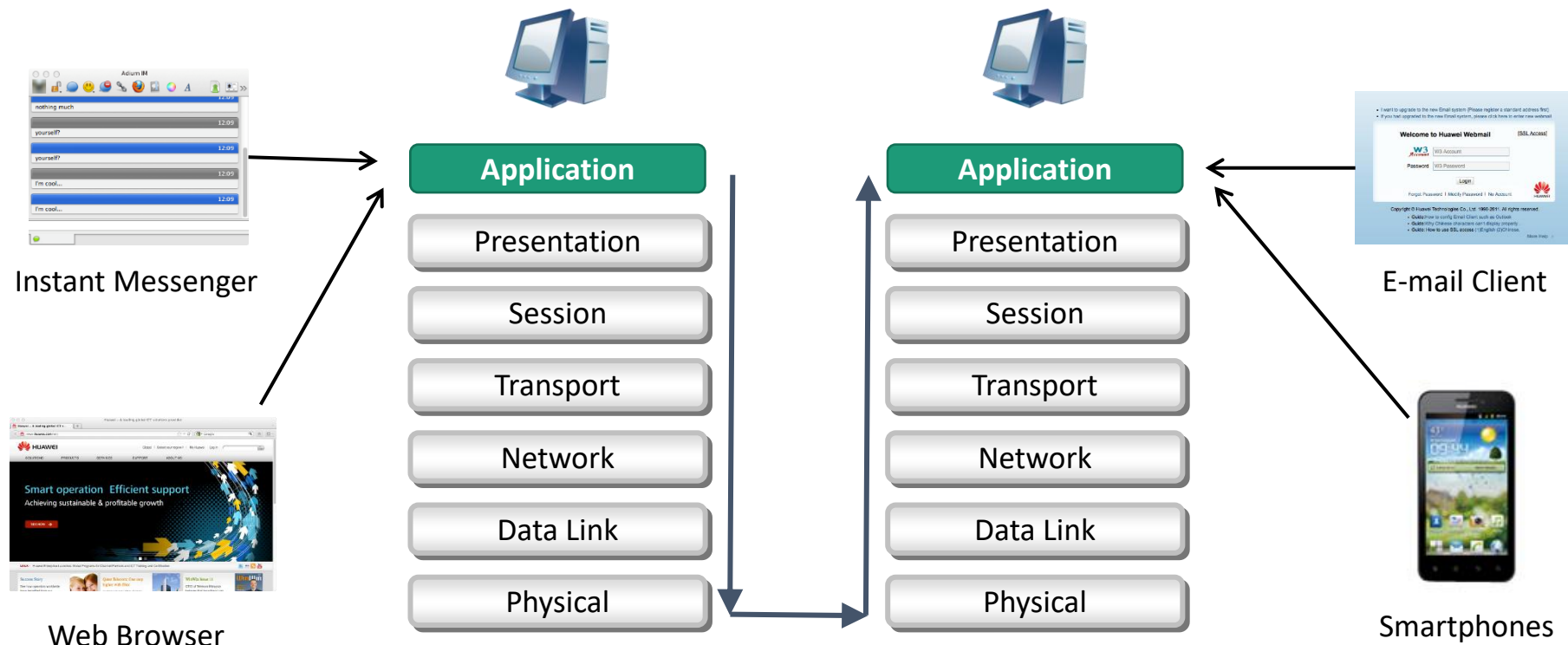
- Connection-oriented
- Reliable
- Message delivery guaranteed
- More overhead
- Comparatively slower
- Suitable for applications that require high reliability

## UDP

- Connectionless
- Unreliable
- Message delivery not guaranteed (best effort)
- Less overhead
- Comparatively faster
- Suitable for applications that require fast transfer
- Reliability depends on application layer

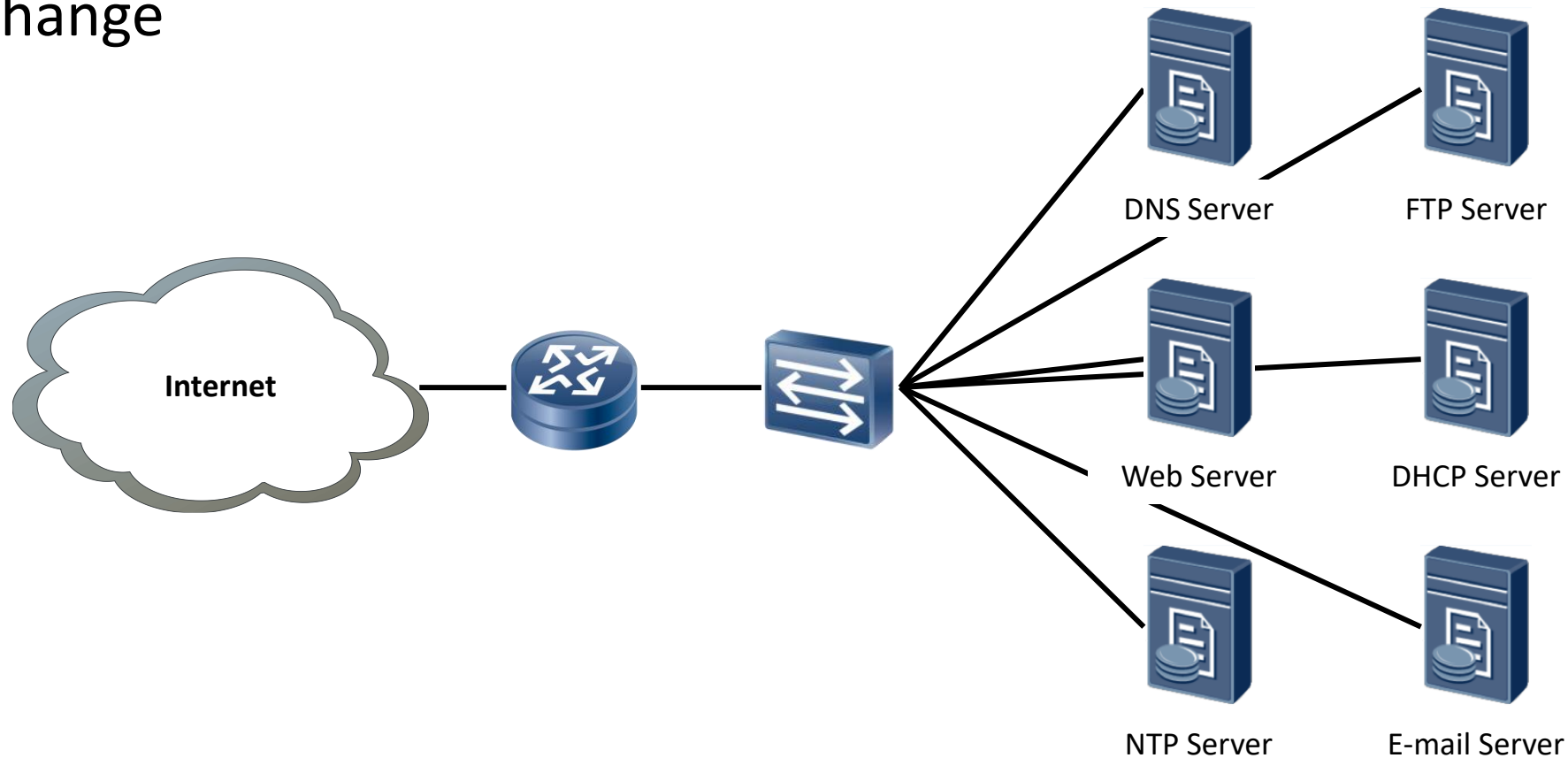
# OSI Layer 7 – Application Layer

- All human-network interactions always carried out through the use of applications or programs



# OSI Layer 7 – Application Layer Protocols

- There are many well-known application layer protocols for data exchange





# Network Threats

Part 2

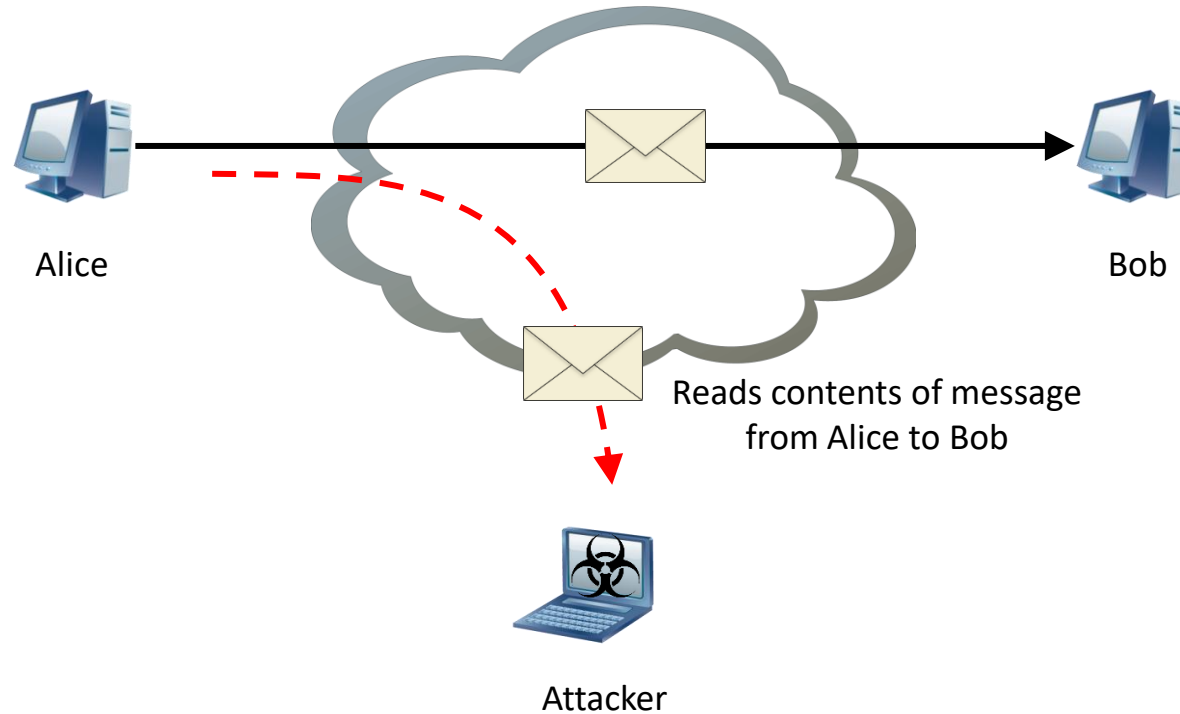


# Classifying Attacks

- Generally, attacks on information security can be categorised into:
  - **Passive Attacks** – information gathering
  - **Active Attacks** – actively making changes to achieve goals

# Passive Attacks

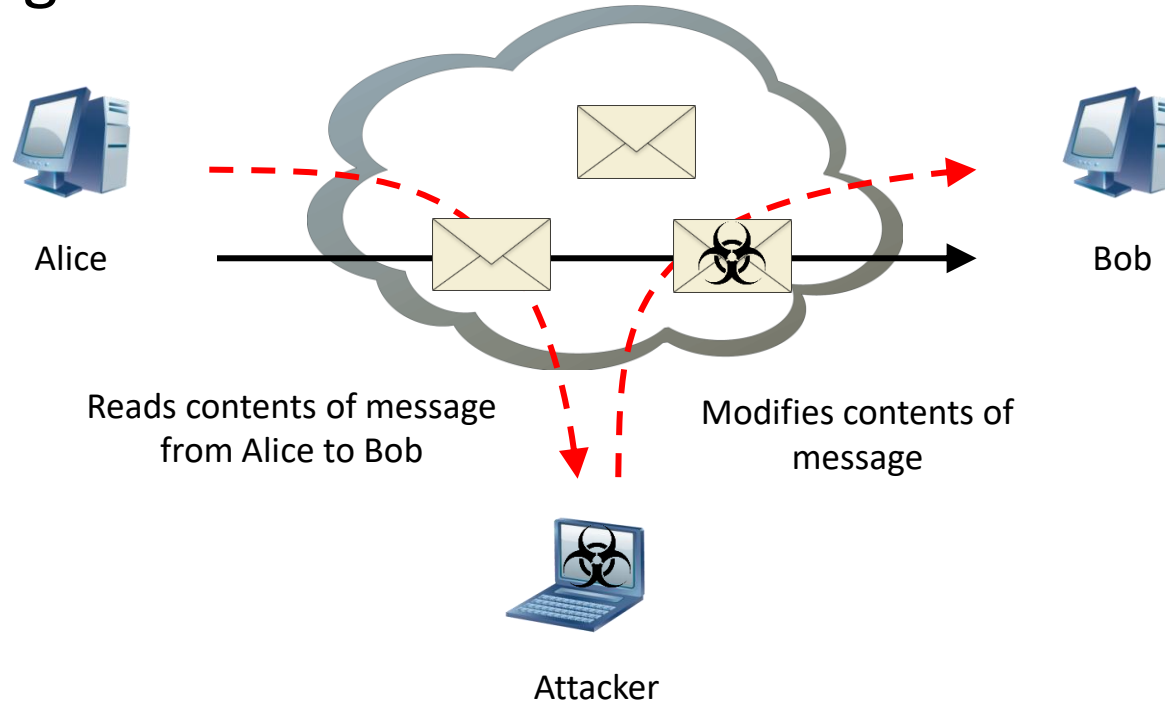
- Gather information through **monitoring and observation** but does **not explicitly affect or change the system**





# Active Attacks

- **Modify data stream or create/falsify of information** i.e. data is purposely changed.



# Passive Network Attacks

## Part 3a



# Passive Attack

- Types of passive attacks:
  1. Eavesdropping
  2. Traffic analysis
  3. Reconnaissance
    - DNS queries
    - OS identification
    - Network scanning and mapping
    - WHOIS queries
- Generally, **encryption** is used to protect confidentiality and prevent observation



# Secure Ports

- Some network protocols transmit information in clear text, meaning it is not encrypted and should not be used. Clear text information is subject to network sniffing.
- This tactic uses software to inspect packets of data as they travel across the network and extract text such as usernames and passwords.
- Network sniffing could also reveal the content of documents and other files if they are sent via insecure protocols.



## INSECURE PORT

**21**  
**FTP**

File Transfer Protocol (FTP) sends the username and password using plaintext from the client to the server..

**23**  
**TELNET**

All information to & from the host on a telnet connection is sent in plaintext & can be intercepted by an attacker

**25**  
**SMTP**

Simple Mail Transfer Protocol (SMTP) is the default for sending email messages. Since it is unencrypted, data contained within the emails could be discovered by network sniffing.

**37**  
**TIME**

Time Protocol, may be in use by legacy equipment and has mostly been replaced by using port 123 for Network Time Protocol (NTP).

**53**  
**DNS**

Domain Name Service (DNS), is still used widely.

**80**  
**HTTP**

Hyper Text Transfer Protocol (HTTP) is the basis of nearly all web browser traffic on the internet. Information sent via HTTP is not encrypted and is susceptible to sniffing attacks

**143**  
**IMAP**

Internet Message Access Protocol (IMAP) is a protocol used for retrieving emails. IMAP traffic on port 143 is not encrypted and susceptible to network sniffing

**445**  
**SMB**

Server Message Block (SMB), is used by many versions of Windows for accessing files over the network. Files are transmitted unencrypted.

**389**  
**LDAP**

Lightweight Directory Access Protocol (LDAP), is used to communicate directory information from servers to clients. Since LDAP is not encrypted, it is susceptible to sniffing and manipulation attacks.



## SECURE PORT

**22**  
**SFTP**

Uses encryption to protect the user credentials and packets of data being transferred.

**22**  
**SECURE SHELL**

Secure Shell (SSH) on port 22 uses encryption to ensure that traffic between the host and terminal is not sent in a plaintext format.

**587**  
**SMTP**

The secure alternative is to use port 587 for SMTP using Transport Layer Security (TLS) which will encrypt the data between the mail client and the mail server.

**123**  
**NTP**

NTP on port 123 offers better error-handling capabilities, which reduces the likelihood of unexpected errors.

**853**  
**DoT**

However, using DNS over TLS (DoT) on port 853 protects DNS information from being modified in transit.

**443**  
**HTTPS**

HTTPS using TLS encryption is preferred, as it protects the data in transit between the server and the browser.

**993**  
**IMAP**

The secure alternative is to use port 993 for IMAP, which adds SSL/TLS security to encrypt the data between the mail client and the mail server.

**2049**  
**NFS**

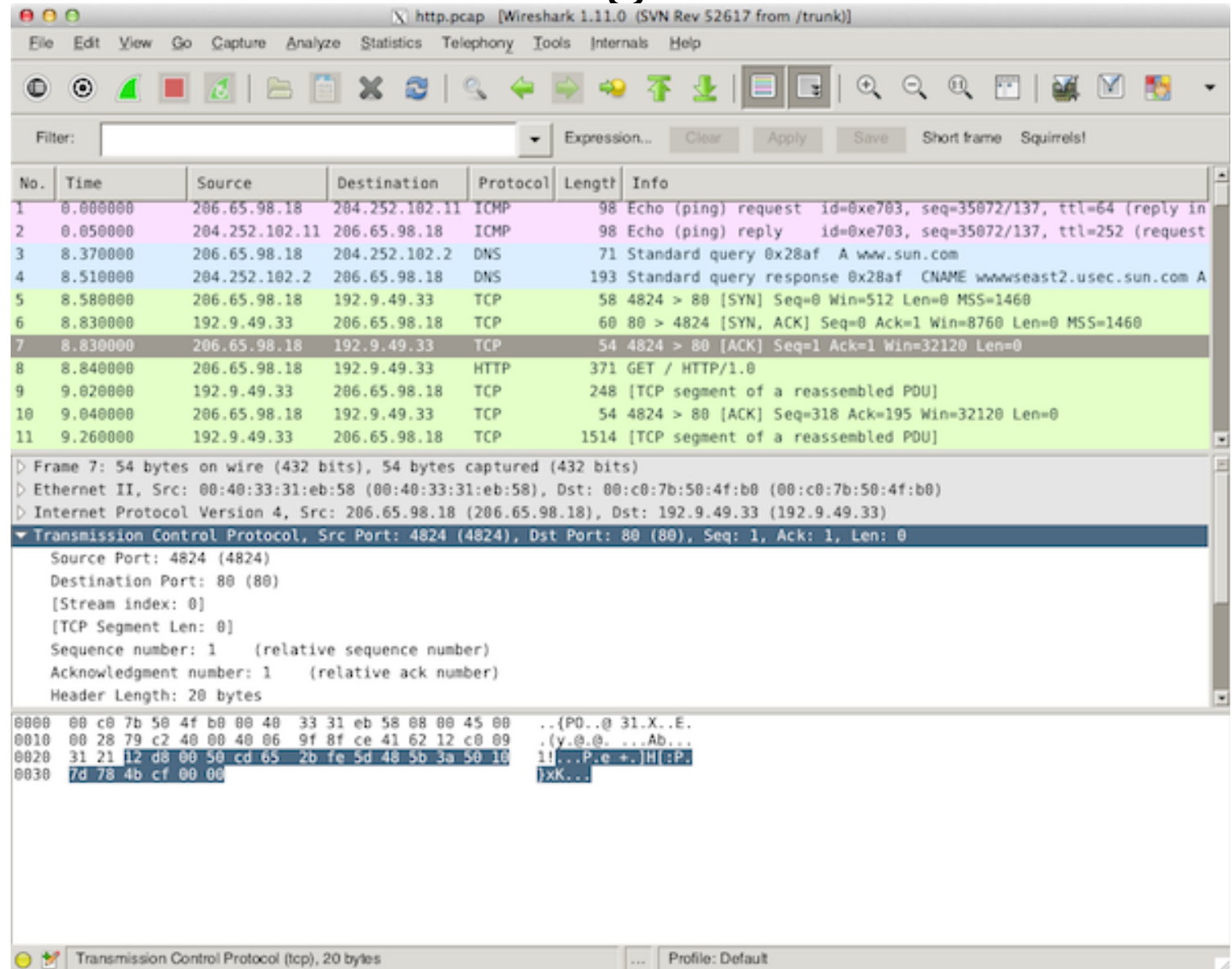
Network File System (NFS). Although NFS can use encryption, it is recommended that NFS not be allowed through firewalls either.

**636**  
**LDAPS**

Lightweight Directory Access Protocol Secure (LDAPS) adds SSL/TLS security to protect the information while it is in transit.

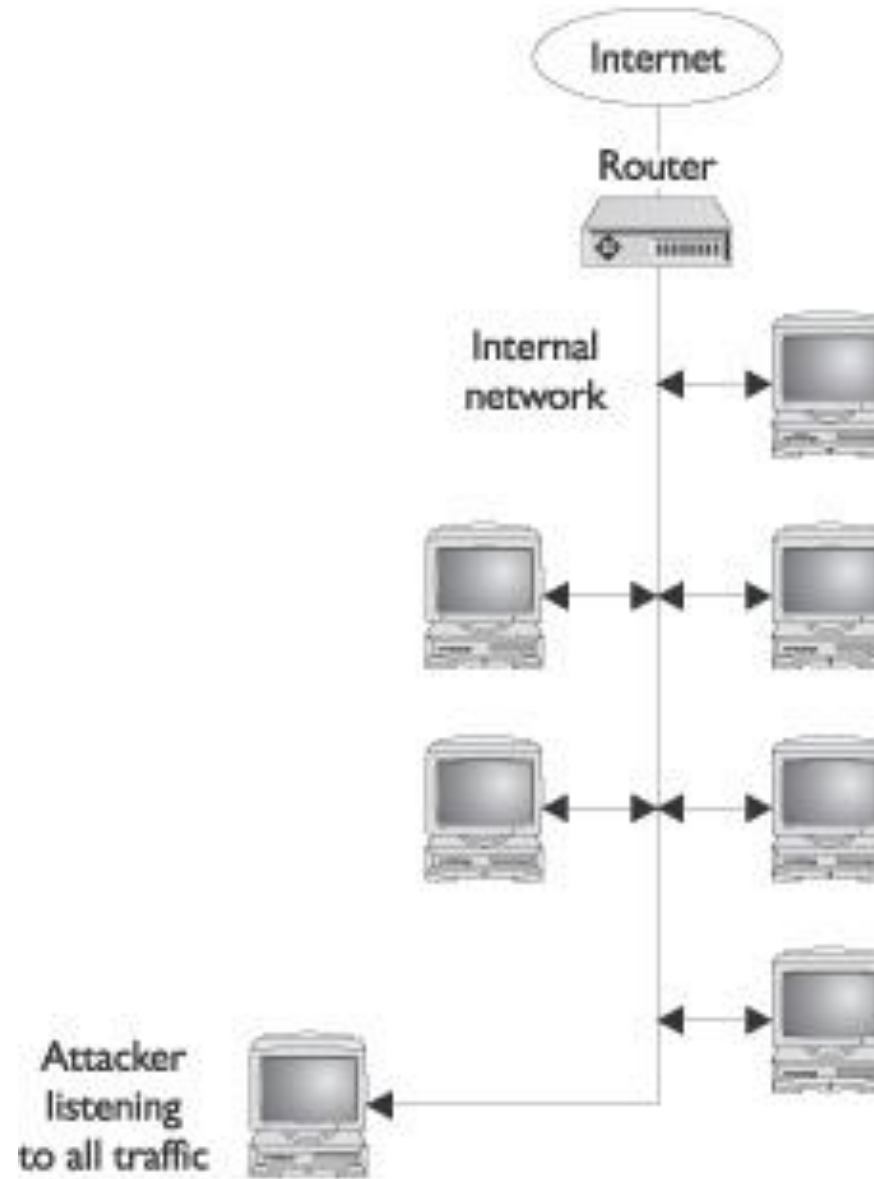
# Eavesdropping or Network Sniffing

- A network sniffer is a software or hardware device used to observe traffic as it passes through a network on shared media
  - It can be used to view all traffic, or it can target a specific protocol, service, or string of characters.



# Eavesdropping or Network Sniffing – *Cont.*

- For network sniffers to be effective, they need to be on the internal network.
- Mitigate by using encryption and network switches



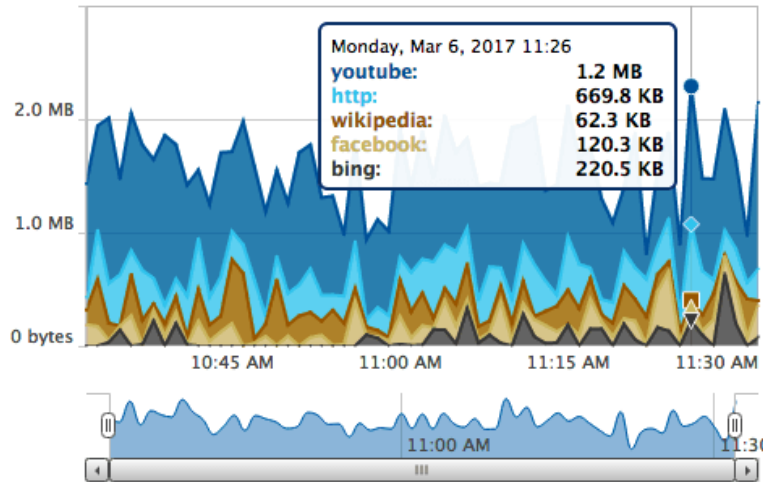
# Traffic Analysis

- Learn about network from observing traffic patterns
- Can identify frequently visited websites, network topology, packet types, running services, etc.
- Mitigate by using encryption or VPN

## Top 5 Applications

INGRESS, LAST HOUR, DATA TRANSFERRED PER TIME INTERVAL

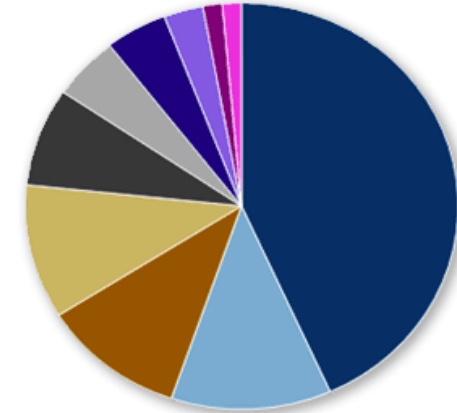
NBAR2



| APPLICATION          | INGRESS BYTES | INGRESS PACKETS | PERCENT |
|----------------------|---------------|-----------------|---------|
| ▶  youtube           | 56.8 Mbytes   | 133.18 k        | 58.52%  |
| ▶  http              | 17.5 Mbytes   | 40.08 k         | 18.05%  |
| ▶  wikipedia         | 11.0 Mbytes   | 24.92 k         | 11.34%  |
| ▶  facebook          | 7.2 Mbytes    | 16.1 k          | 7.45%   |
| ▶  bing              | 4.3 Mbytes    | 8.38 k          | 4.38%   |
| ▶  Remaining traffic | 244.8 kbytes  | 500             | 0.25%   |

## Top 10 Receivers

INGRESS, LAST HOUR



| HOSTNAME         | INGRESS BYTES | INGRESS PACKETS | PERCENT |
|------------------|---------------|-----------------|---------|
| ▶  1e100.net     | 39.8 Mbytes   | 92.38 k         | 43.28%  |
| ▶  wikipedia.org | 11.0 Mbytes   | 24.92 k         | 11.98%  |
| ▶  blogger.com   | 9.9 Mbytes    | 24.82 k         | 10.73%  |
| ▶  msn.com       | 9.8 Mbytes    | 22.02 k         | 10.67%  |
| ▶  go.com        | 7.2 Mbytes    | 15 k            | 7.86%   |
| ▶  Thwack.com    | 4.6 Mbytes    | 11.62 k         | 5.05%   |
| ▶  google.com    | 4.3 Mbytes    | 8.38 k          | 4.63%   |
| ▶  amazon.com    | 2.7 Mbytes    | 5.78 k          | 2.96%   |
| ▶  cnn.com       | 1.3 Mbytes    | 2.56 k          | 1.43%   |
| ▶  yahoo.com     | 1.3 Mbytes    | 3.56 k          | 1.42%   |



# Reconnaissance

- Sometimes referred to as *footprinting*
- It is the process of **collecting information** about the target system
- Various techniques and tools used, such as:
  - DNS queries
  - OS identification
  - Network scanning and mapping
  - WHOIS queries

# DNS Queries

- A DNS query (also known as a DNS request) is used to identify the associated IP addresses for a given domain name
- Useful to identify critical servers that can be potential targets

## DNS Lookup Tool

Enter a host name or domain name:

mmu.edu.my

Go »

Answer

Trace

mmu.edu.my results:

ext-dns-4.mmu.edu.my.

A

257 ms

|    |              |      |
|----|--------------|------|
| IN | 203.106.62.9 | 3600 |
|----|--------------|------|

TXT

248 ms

|    |                                                                                                                                                                                                                            |      |
|----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| IN | "v=spf1 include:_spf.google.com ip4:203.106.62.37 ip4:203.106.61.37 ip4:203.106.60.37 ip4:203.106.63.37 ip4:203.106.62.40 ip4:203.106.61.40 ip4:203.106.60.40 ip4:203.106.63.40 ip4:203.106.61.39 ip4:203.106.62.151 ~all" | 3600 |
|----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|

# OS Identification

- A special software sends a series of TCP/UDP packets to remote host and observes the responses
  - Different OSes implement the TCP/IP stack differently and therefore, responses will be unique
  - Software will compare the unique responses against an OS fingerprint database and provide best guess
- Using this information, attacker can launch specific attacks on known vulnerabilities of that OS
- To minimise, disable unused ports and turn on firewall

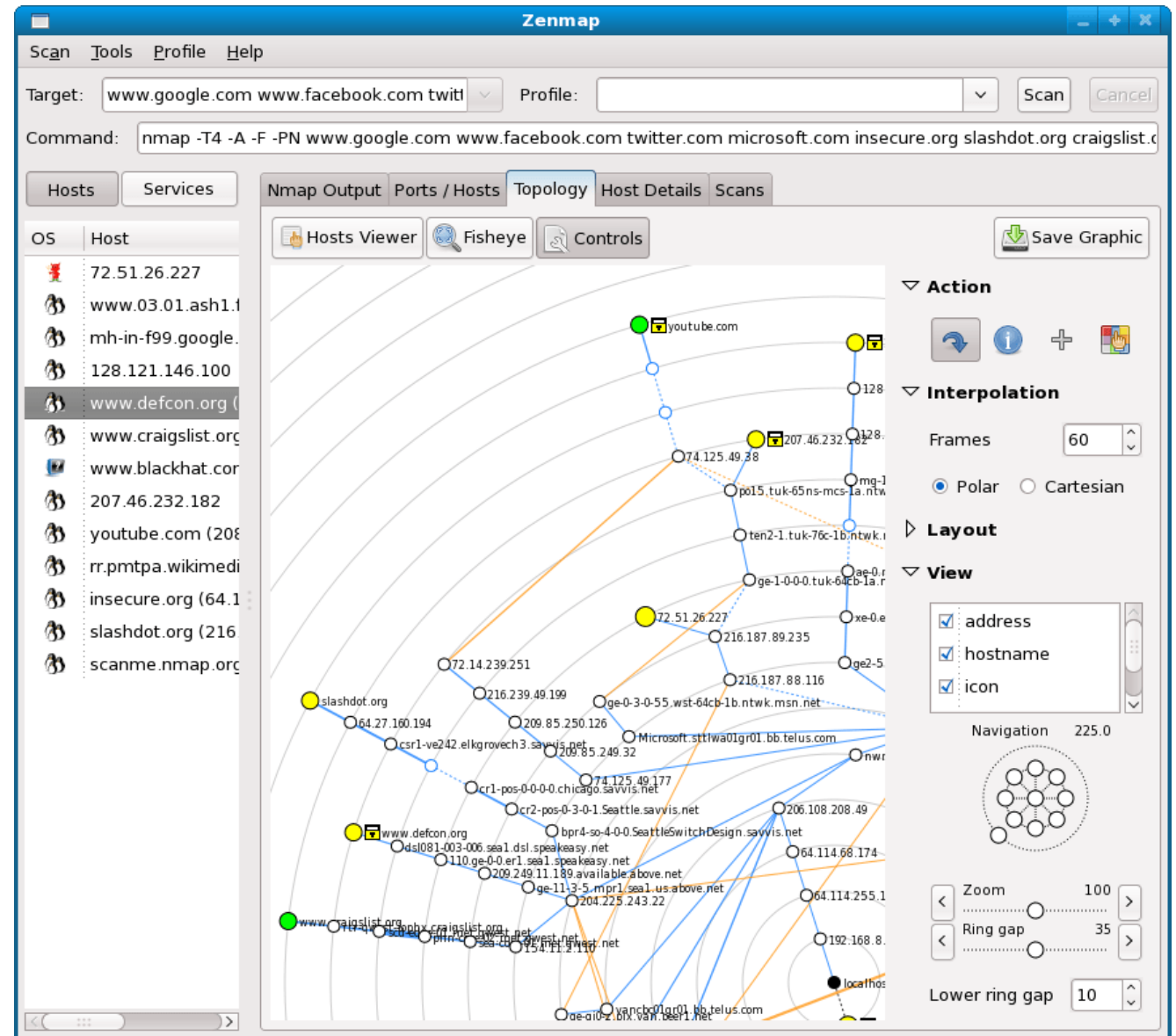
```
root@EthicalHaks:~# nmap -A 192.168.0.9

Starting Nmap 7.12 ( https://nmap.org ) at 2016-07-23 21:49 PDT
Nmap scan report for 192.168.0.9
Host is up (0.000058s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE VERSION
111/tcp    open  rpcbind 2-4 (RPC #100000)
|_ rpcinfo:
|   program version  port/proto  service
|   100000   2,3,4      111/tcp    rpcbind
|   100000   2,3,4      111/udp    rpcbind
|   100024   1          46044/udp  status
|_   100024   1          54793/tcp  status
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.8 - 4.4
Network Distance: 0 hops

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.71 seconds
```

# Network Scanning and Mapping

- Utilise special software to scan layout of computing infrastructure
- Useful to gain knowledge of network layout
  - Can guess organisational structure and importance
- Mitigation:
  - Enable Windows firewall
  - Disable unused ports on routers and switches



# WHOIS Queries

- WHOIS (pronounced "who is") is an Internet service used to look up information about a domain name
  - Registrant
  - Contact Information
  - Billing Information
  - Expiry Date
- Useful to obtain information about owner of a domain

| WHOIS Result                                                                                                   |                                                                                                                          |
|----------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| Domain Name                                                                                                    | mmu.edu.my                                                                                                               |
| Registration No.                                                                                               | D5A000024                                                                                                                |
| Record Created                                                                                                 | 24 June 1999                                                                                                             |
| Record Expired                                                                                                 | 24 June 2020                                                                                                             |
| Record Last Modified                                                                                           | 12 June 2019                                                                                                             |
|                                                                                                                |                                                                                                                          |
| Invoicing Party                                                                                                | Registrant                                                                                                               |
| MYNIC Berhad<br>Level 3, Tower 2, Menara Cyber Axis<br>Jalan Impact<br>63000 Cyberjaya<br>Selangor<br>Malaysia | Multimedia University (436821-T)<br>Multimedia University<br>Jalan Multimedia<br>63100 Cyberjaya<br>Selangor<br>Malaysia |

# Active Network Attacks

Part 3b



# Active Attack

- Types of active attacks:
  1. URL Spoofing
  2. Denial of Service
    - Volumetric
    - Buffer Overflow
    - Protocol Attack
    - Distributed
  3. Evil Twin Access Point
  4. Impersonation
    - Replay
    - MiTM
    - Session Hijacking
    - Network Spoofing – IP and ARP spoofing
- Generally, **hash functions and digital signatures** can be used to protect integrity and prevent an attacker maliciously changing the messages during transmission from sender to receiver

# URL Spoofing

- In URL spoofing, attackers acquire a URL close to the one they want to spoof in order to confuse users
  - Without realising it, users will key in their username and passwords to fake websites
- Examples:
  - <https://www.amazonn.com>
  - <https://drive--google.com>
  - <https://maybank2u.net.my/>
  - <https://www.xn--80ak6aa92e.com/>
- Mitigation:
  - Carefully ensure that the URL is correct. If unsure, use Google
  - Ensure that SSL/TLS certificates are valid
  - Do not click on links provided in emails. Instead, go directly to website if address is known or use Google



# Denial-of-Service (DoS)

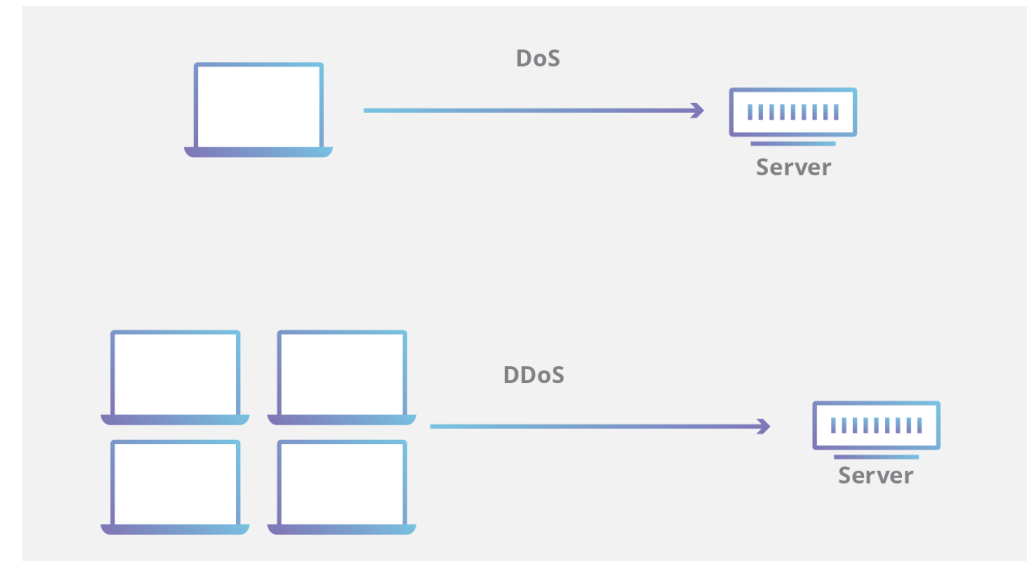
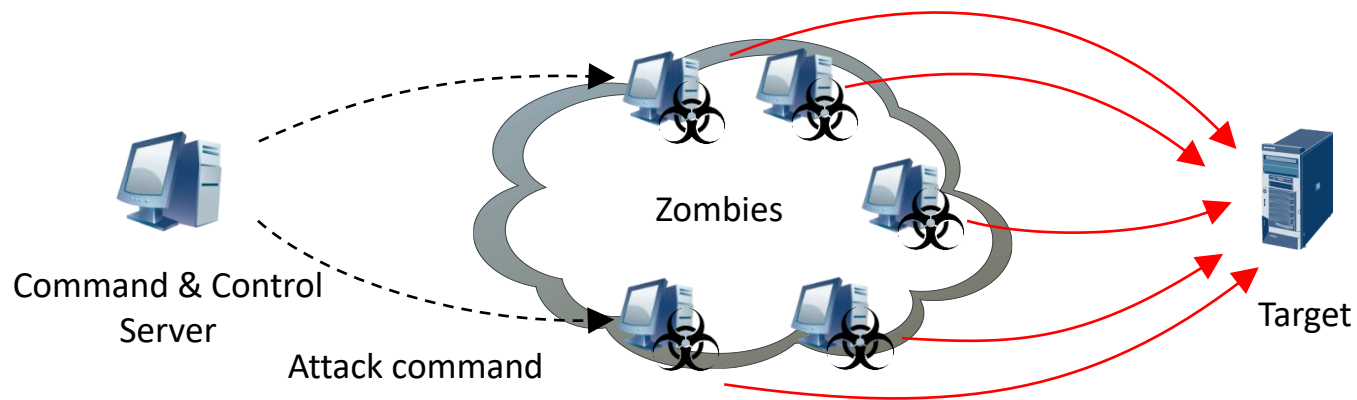
- Denial-of-service attacks are designed to shut down or **render inoperable** a system or network
- It is called a denial-of-service attack, because the end result is to deny legitimate users access to network services
- The goal of the Denial-of-Service (DoS) attack is not to gain access or information but to make a network or system unavailable for use by other users
- DoS Attacks launched from a **single computer**

# Types of DoS Attacks

- Volumetric (Flood) Attacks
  - Saturate a targeted server with an overwhelming amount of packets
  - Overwhelms bandwidth, ports, and computing resources
- Buffer Overflow Attacks
  - Memory buffer overflow can cause a machine to consume all available hard disk space, memory, or CPU time
  - Server becomes sluggish and crashes
- Protocol Attacks
  - Exploit network protocols' normal behaviour to cause unexpected results such as delays and overloaded resources

# Distributed Denial-of-Service (DDoS)

- Similar to DoS but attacks launched from **multiple computers**
- Usually achieved through the use of botnets
  - Each zombie computer launch a DoS attack, thus creating a multiplier effect with many zombies
  - Zombie computers have been hijacked using malwares



# DDoS – *Digital Attack Map*



<https://www.digitalattackmap.com/>



# DoS and DDoS Mitigation

- Although some DoS and DDoS attacks are hard to differentiate from regular traffic, some preventive steps can be taken
  - Leverage cloud services – resources can be scaled up to cope with heavier traffic
  - IP whitelist/blacklist – allow/block traffic from specific IP addresses
  - Understand traffic patterns – Unusually high traffic can be symptoms of attacks
  - Outsource server hosting to specialised hosting services – some hosting services have technology to detect, prevent, absorb, or redistribute DoS or DDoS traffic

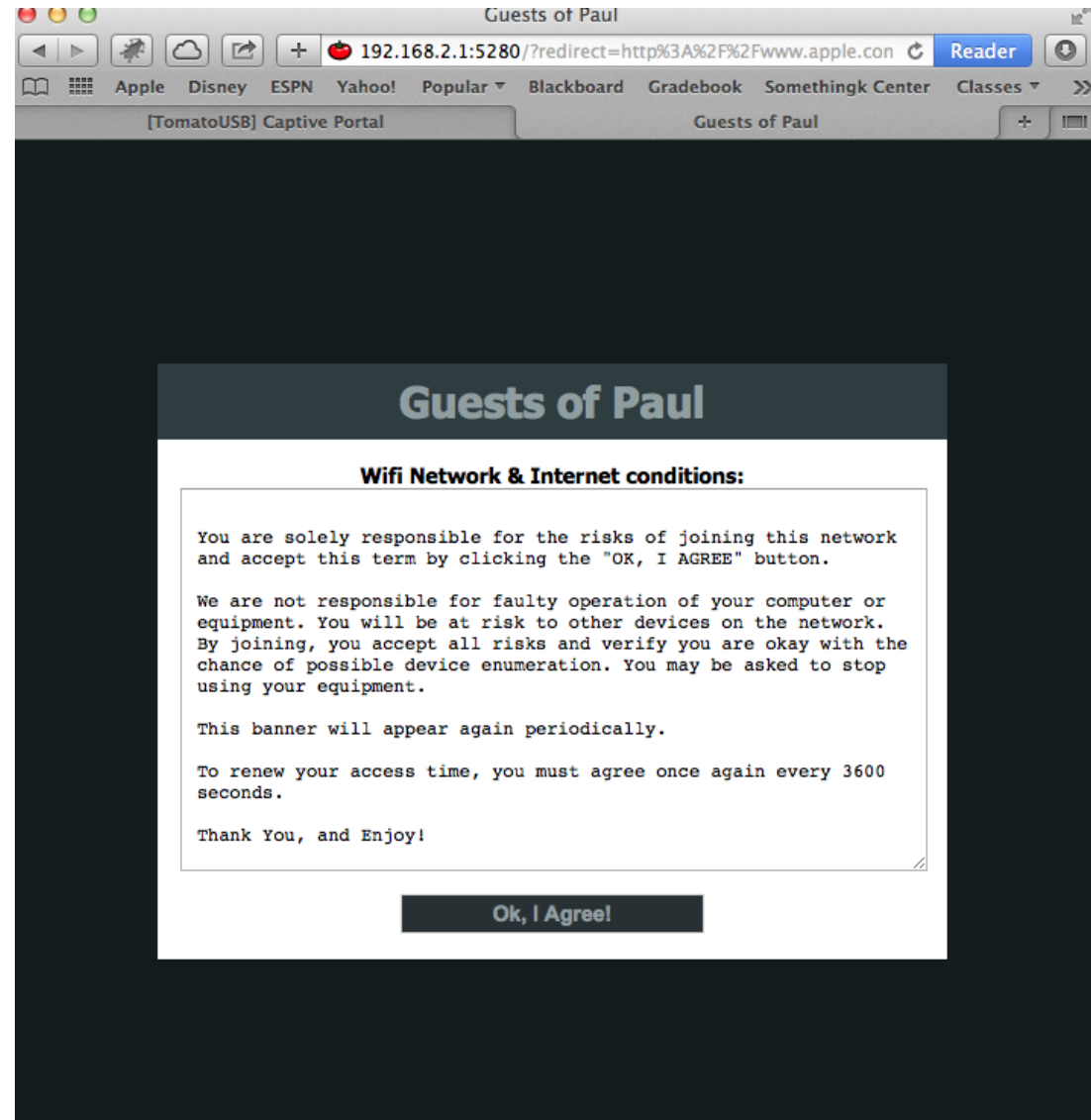


# What is WiFi?

- Wireless networking is a popular method of connecting corporate and home systems because of the ease of deployment and relatively low cost. It has made networking more versatile than ever before. Workstations and portable systems are no longer tied to a cable but can roam freely within the signal range of the deployed wireless access points. However, with this freedom comes additional vulnerabilities.
- Wi-Fi range is generally wide enough for most homes or small offices, and range extenders may be placed strategically to extend the signal for larger campuses or homes. Over time the Wi-Fi standard has evolved, with each updated version faster than the last.
- In a LAN, threat actors need to enter the physical space or immediate vicinity of the physical media itself. For wired networks, this can be done by placing sniffer taps onto cables, plugging in USB devices, or using other tools that require physical access to the network. By contrast, wireless media intrusions can happen at a distance.

# Evil Twin Access Point (Public WiFi)

- Hackers can perform Man-in-the-Middle attacks.
- Set up fake free WiFi hotspots that lure users to connect.
- Malicious scripts can be uploaded to connected clients through the splash page.
- Once connected, hackers can conduct either
  - 1) Passive attacks – monitor the sites you visit
  - 2) Active attacks – capture your login credentials and use it for themselves



Source: <http://somethingk.com/main/?tag=tomato-shibby>

# Evil Twin Access Point Mitigation

- Evil Twin Access Points are almost impossible to detect or differentiate.
- To prevent potential attacks
  - Avoid connecting to public WiFi
  - Use VPN to encrypt all network traffic
  - Do not do use authentication services (i.e. logins)



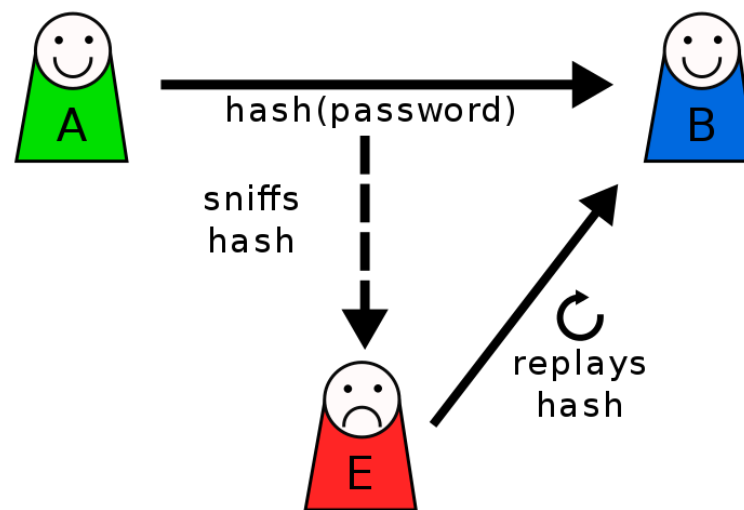


# Impersonation

- Impersonation is pretending to be someone else
  - Sometimes referred to as masquerading or spoofing
- In networking, impersonation can be carried out using
  - Replay attack
  - Man-in-the-middle
  - Session Hijacking
  - Network-based spoofing
    - IP spoofing
    - ARP spoofing

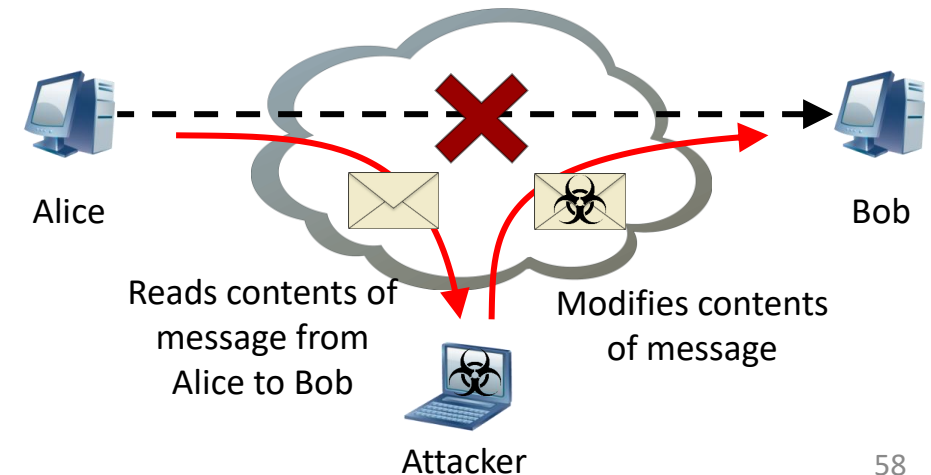
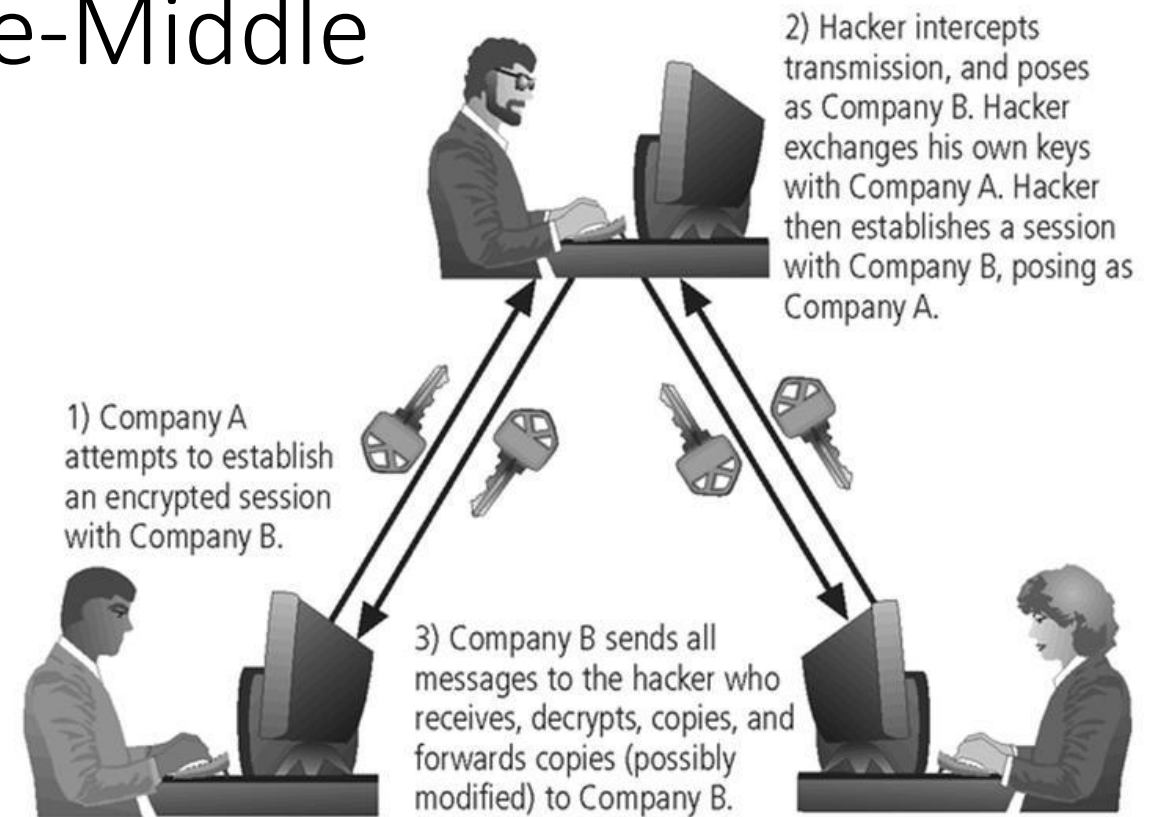
# Impersonation – Replay Attacks

- Attacker first intercepts a legitimate message and retransmits it at a later time
- Example: Intercepting a password from a legitimate user, and then reusing the password again later to impersonate the user
- Mitigation
  - Include liveness tokens (i.e. timestamps)
  - Use session keys instead of permanent keys



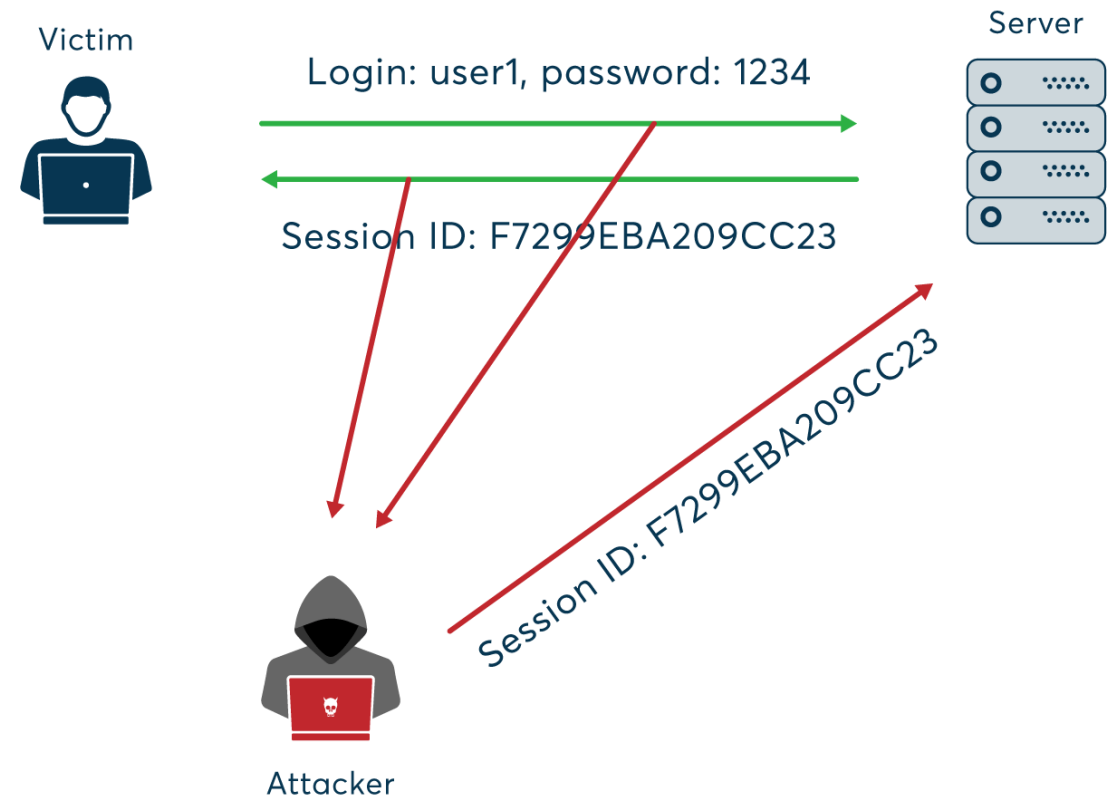
# Impersonation – Man-in-the-Middle

- Attacker forces itself to be a middleman between two communicating devices
  - Compromise network device
  - Phishing webpage
  - Use network-based spoofing methods
- Mitigation
  - Use end-to-end encryption such as Virtual Private Network
  - Do not connect to public or unknown network or WiFi



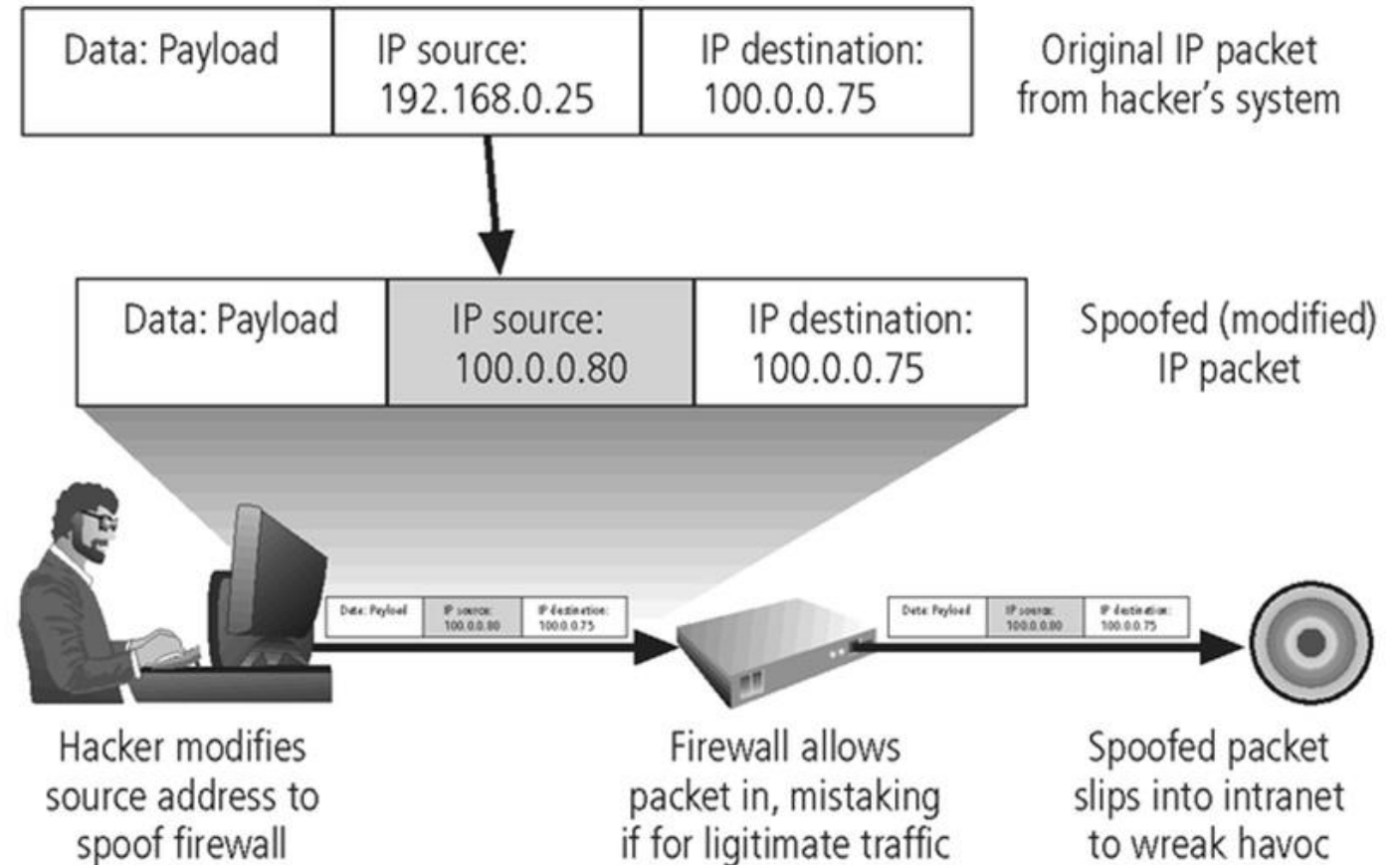
# Impersonation – Session Hijacking

- In session hijacking, a hacker takes over a connection session, usually between a client user and a server
- Generally done by gaining access to a gateway device between the legitimate user and the server
  - Example: Capturing the session cookie and using it on another computer



# Impersonation – IP Spoofing

- Technique used to gain unauthorised access whereby the intruder sends messages to a computer with an IP address indicating that the message is coming from a trusted host
- Packet-filtering routers are sometimes used to protect an internal network from an external un-trusted network. These routers will only allow specified IP addresses to pass from the external network to the internal network.
- If a hacker is able to determine an IP address that is permitted access through the router, he or she can spoof the address on the external network to gain access to the internal network.

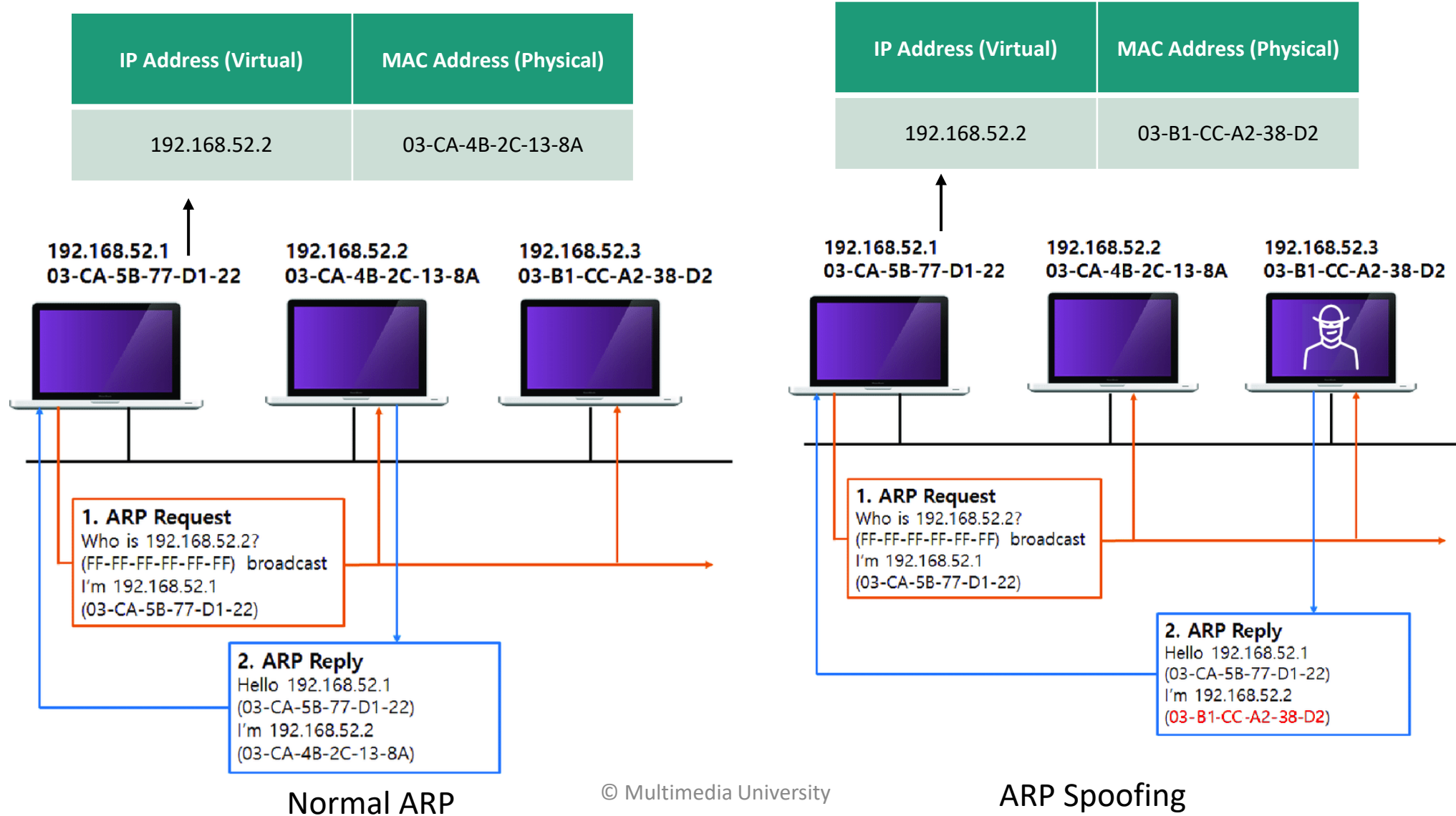


# Impersonation – ARP Spoofing

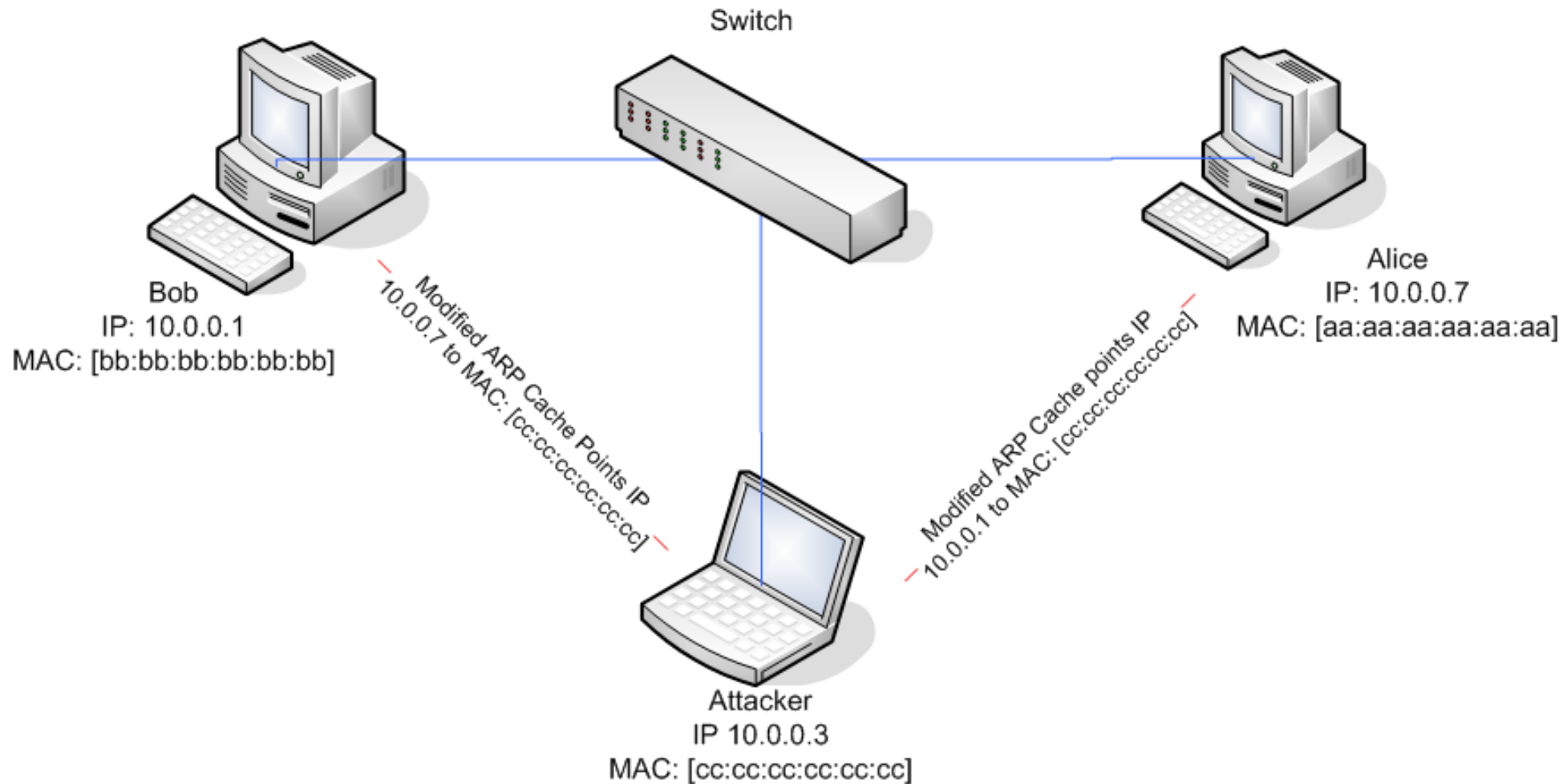
- In order to send data, computers need to know the physical (MAC) address of the virtual (IP) address
- Address Resolution Protocol (ARP) creates a mapping of physical and virtual addresses
- Involves constructing forged ARP replies
- Takes advantage of the ARP cache
- Process of corrupting cache is “Poisoning”

| ARP Cache            |                        |
|----------------------|------------------------|
| IP Address (Virtual) | MAC Address (Physical) |
| 192.168.0.1          | 68-ff-7b-43-ba-94      |
| 192.168.0.2          | 00:0a:95:9d:68:16      |
| 192.168.0.2          | ?                      |

# Impersonation – ARP Spoofing – *Cont.*



# MITM using ARP Spoofing





# Mitigating Network Attacks

Part 3



# Mitigating Network Attacks

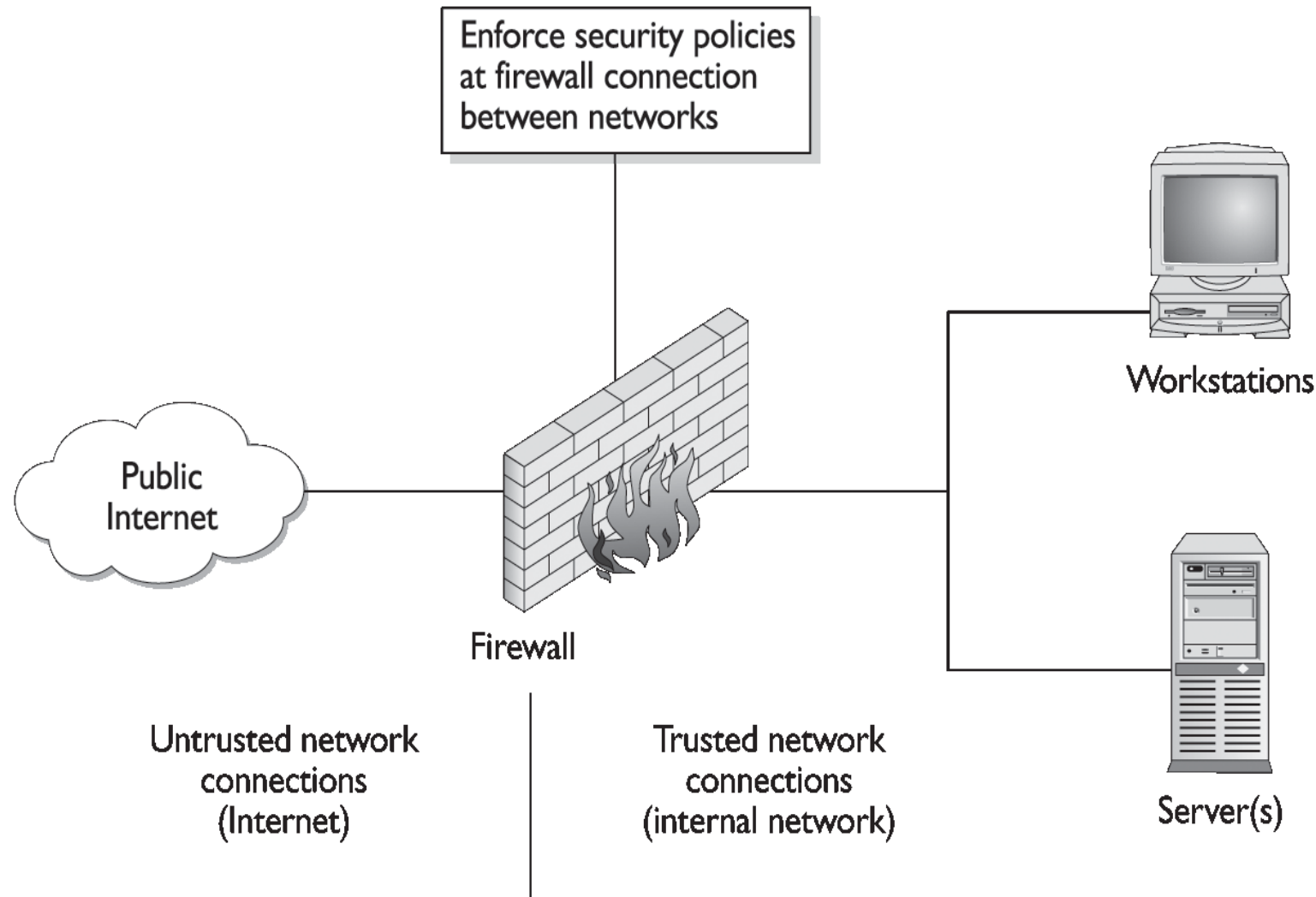
- Firewalls
- Intrusion Detection Systems
- Virtual Private Networks
- IPSec

# Firewall

## Part 3a

# Firewalls

- A firewall is a network device — hardware, software, or a combination of both
- It **permits or blocks electronic access** to a networked computer system by enforcing security policies





# Security Policies

- A security policy or firewall policy is a series of rules that define what traffic is permissible and what traffic is to be blocked or denied.
- A key to security policies for firewalls is the principle of least access.
  - Only allow the necessary access for a function, and block or deny all unneeded functionality.



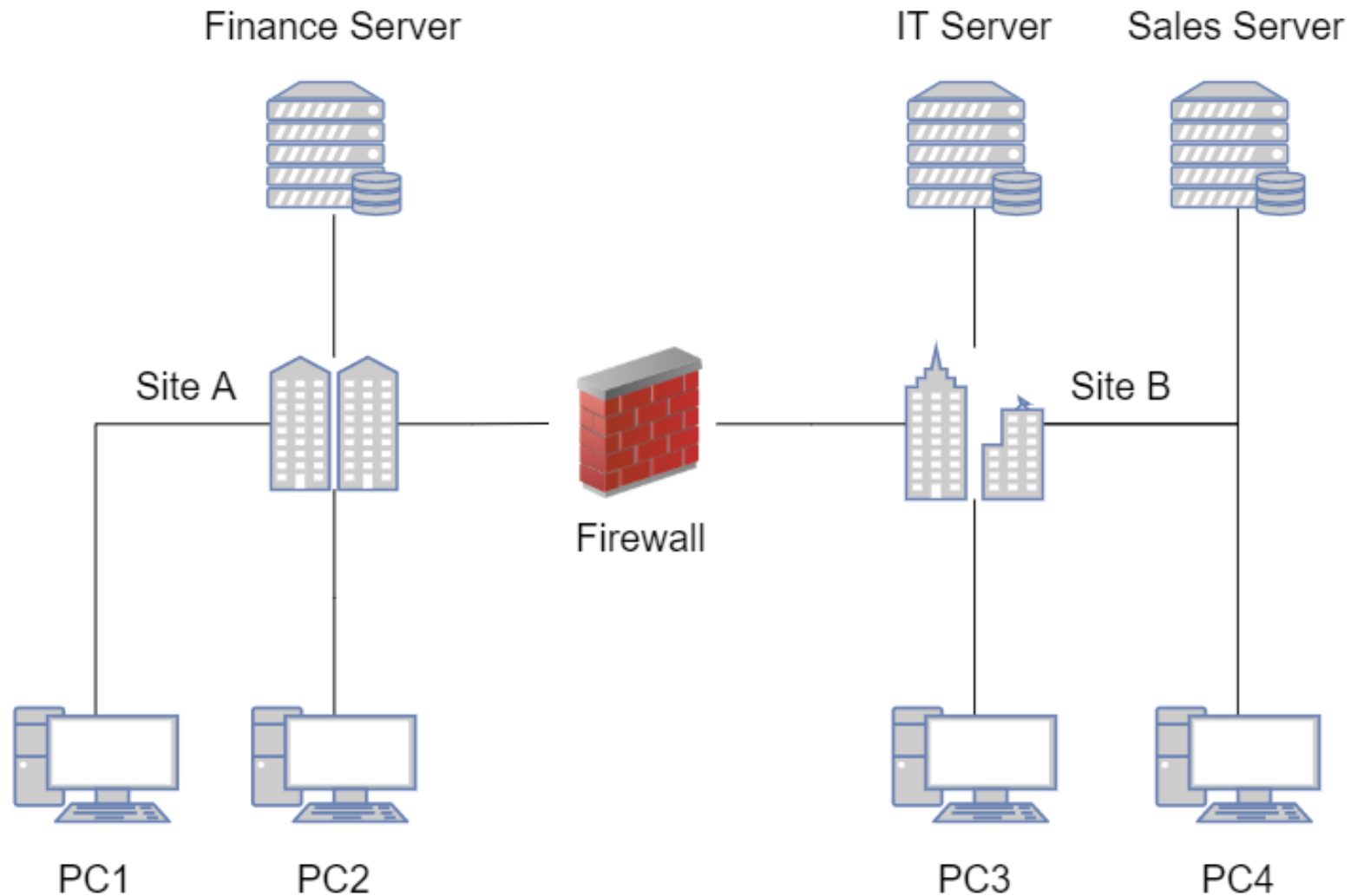
# Policy Actions

- Packets flowing through a firewall can have one of three outcomes:
  - **Accepted**: permitted through the firewall
  - **Dropped**: not allowed through, with no indication of failure
  - **Rejected**: not allowed through, accompanied by an attempt to inform the source that the packet was rejected
- Policies used by the firewall to handle packets are based on several properties of the packets being inspected such as:
  - Protocol used; TCP or UDP
  - Source and destination IP addresses
  - Source and destination ports



# Example Security Policies

| Source Address | Destination Address | Protocol | Action |
|----------------|---------------------|----------|--------|
| PC1            | IT Server           | TCP      | Accept |
| PC2            | Sales Server        | TCP      | Drop   |
| PC3            | Site A              | UDP      | Accept |

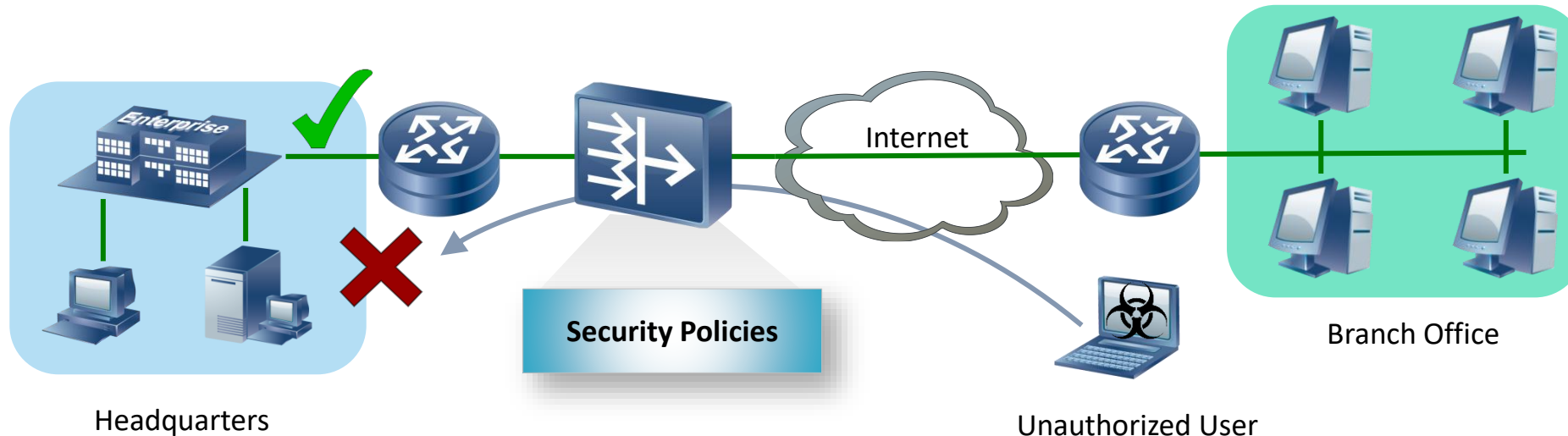


# Types of Firewalls

- There are different types of firewalls that enforce security policies:
  - Stateless firewall (Basic packet filters)
  - Stateful firewall
  - Application-layer proxy firewall

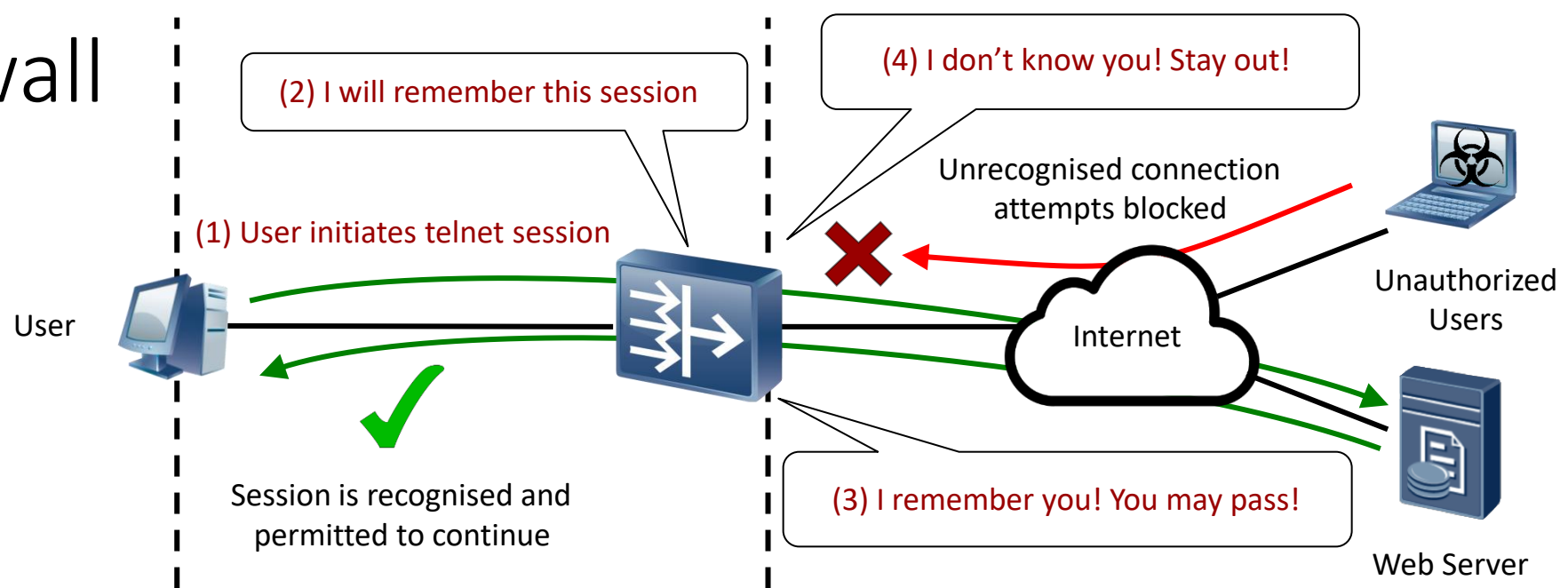
# Stateless Firewall

- Basic packet filtering involves examining packets headers, checking for:
  - Protocol used; TCP or UDP
  - Source and destination IP addresses
  - Source and destination ports
- Each packet is examined independently of each other
- Uses simple matching algorithm
  - **If details in packet headers match exactly, either *Accept/Permit* or *Drop/Deny***



1. Permit FROM Branch Office TO Headquarters
2. Deny FROM 10.0.2.3 TO Headquarters
3. Deny FROM \* TO Headquarters

# Stateful Firewall



- A Stateful firewall is aware of active connections that pass through it
  - It can tell when packets are part of legitimate sessions originating from a trusted network.
- Stateful firewalls maintain information about active connections in a **state table**, containing
  - Source and destination IP addresses
  - Source and destination ports
  - Sequence numbers of packets.
- Using these tables, stateful firewalls can examine each packet **in-context**
  - Keeps track of client-server sessions
- Example: If a packet arrives from outside the network with no record of it being requested, the firewall will block access by dropping it

# Stateful Firewall – Example State Table

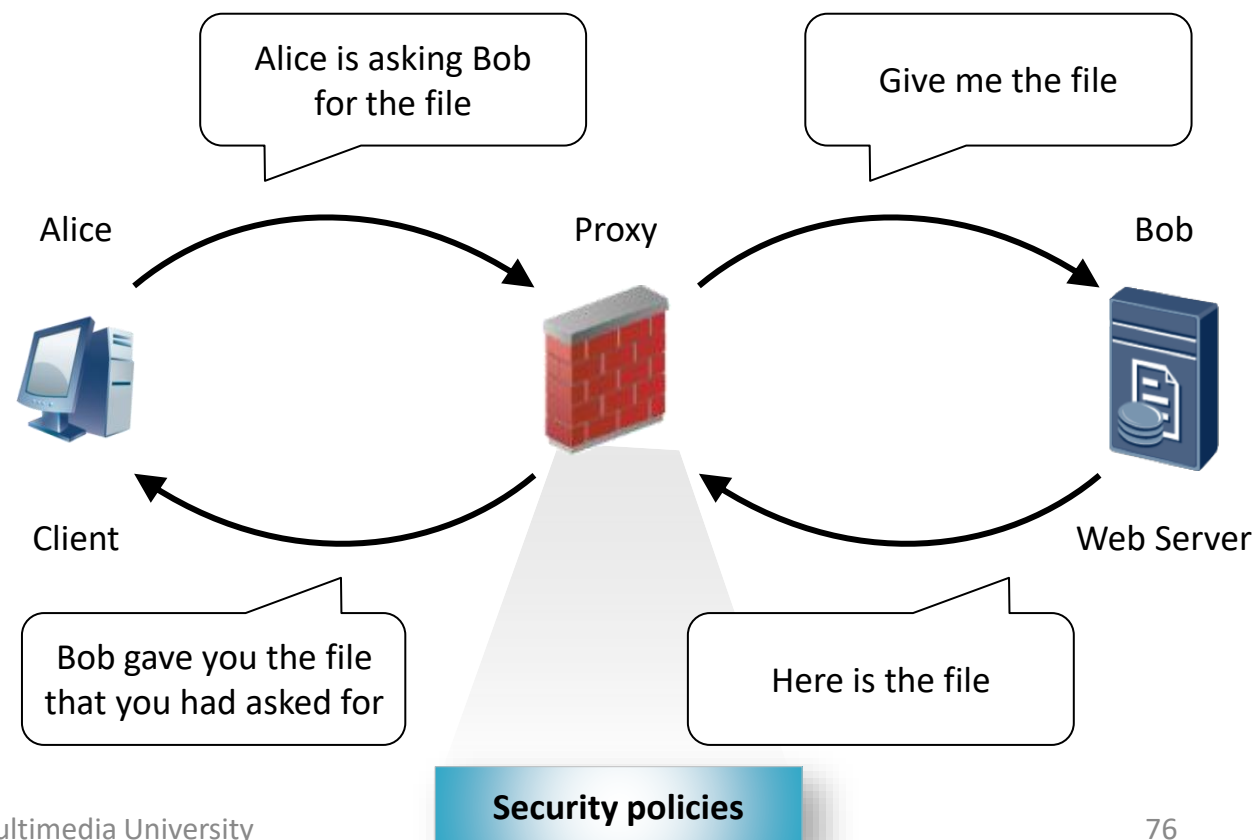
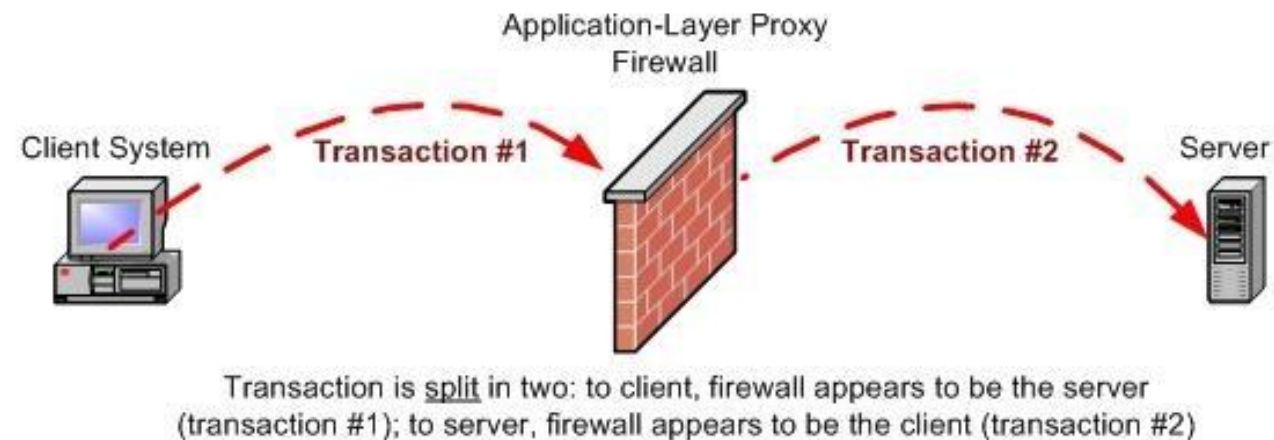
| Source Address | Source Port | Destination Address | Destination Port | Connection State |
|----------------|-------------|---------------------|------------------|------------------|
| 192.168.1.100  | 1030        | 210.9.88.29         | 80               | Established      |
| 192.168.1.102  | 1031        | 216.32.42.123       | 80               | Established      |
| 192.168.1.101  | 1033        | 173.66.32.122       | 25               | Established      |
| 192.168.1.106  | 1035        | 177.231.32.12       | 79               | Established      |
| 223.43.21.231  | 1990        | 192.168.1.6         | 80               | Established      |
| 219.22.123.32  | 2112        | 192.168.1.6         | 80               | Established      |
| 210.99.212.18  | 3321        | 192.168.1.6         | 80               | Established      |
| 24.102.32.23   | 1025        | 192.168.1.6         | 80               | Established      |
| 223.212.212    | 1046        | 192.168.1.6         | 80               | Established      |

# Difference between Stateful and Stateless Firewall

| Stateful Firewall                                                                                      | Stateless Firewall                                                                      |
|--------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>• Examines packets collectively</li></ul>                        | <ul style="list-style-type: none"><li>• Examines each packet independently</li></ul>    |
| <ul style="list-style-type: none"><li>• Context-aware using a state table</li></ul>                    | <ul style="list-style-type: none"><li>• Not aware of context or relationships</li></ul> |
| <ul style="list-style-type: none"><li>• Filters using static values <b>and</b> context/state</li></ul> | <ul style="list-style-type: none"><li>• Filters using static values</li></ul>           |

# Application-layer Proxy

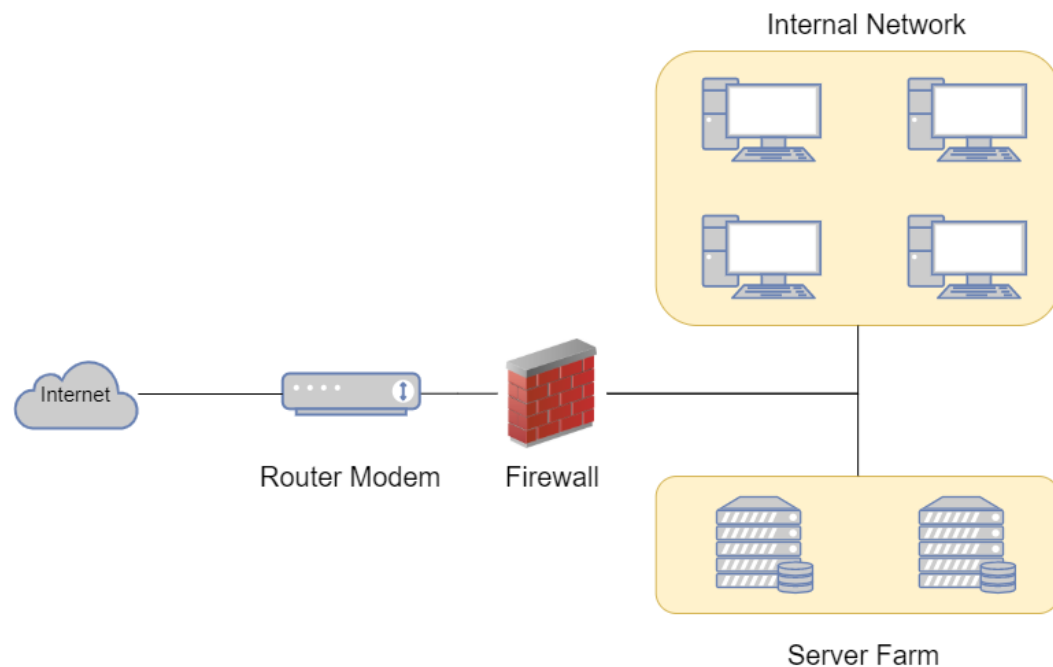
- Application-layer Proxy Firewall can monitor and filter on the application layer
  - **It examines the contents of the packets, not the headers**
- Designed to relay requests and responses between endpoints
- Functions as an intermediary that relays requests and responses between client and server
  - Hides internal devices from external network
  - Analyses incoming traffic for irregularities before forwarding to client
  - Provides caching features as well





# Placing Firewalls in Networks

- Packet filters usually placed at border between internal and external networks:
  - Location should be the only transit point (i.e. all network traffic passes through the firewall for inspection)





# Limitations of Firewalls

- Firewall should not be taken as **the** solution to all network security problems:
  - Protects internal network from external network; not effective for insider attacks
  - Uses predefined rules and therefore cannot detect previously unseen attacks
  - Cannot analyse encrypted traffic
  - Susceptible to *single point of failure* problem; if firewall fails, all access to external networks stops
  - Firewalls must be correctly configured and security policies must be updated accordingly

# INTRUSION DETECTION SYSTEM (IDS)

Part 4b



# Intrusion Detection System (IDS)

- IDS is a device or software that monitors a network or system for malicious activity or policy violations
- Any intrusion activity or violation is typically reported either to an administrator or collected centrally using a Security Information and Event Management (SIEM) system
- Early intrusion detection systems worked by analysing system logs to spot potential misuses that had occurred
- Modern intrusion detection systems operate similarly but in real-time and with more parameters being monitored



# Categorising IDS

- IDS can be categorised based on:
  - **What** is being monitored
  - **How** it functions
- **What** is being monitored:
  - **Network-based** – attached to network to monitor network traffic
  - **Host-based** – installed in computer to monitor computer
- **How** it functions:
  - **Signature-based detection** – detect by matching malicious activity with pre-defined patterns/signatures
  - **Anomaly-based detection** – detect using machine learning or statistical algorithms



# Network Threats and Attacks

- Intrusion Detection System (IDS) is a form of monitoring to detect abnormal activity; it detects intrusion attempts and system failures. Identifies Threats, Do not prevent threats
- Host-based IDS (HIDS) monitors activity on a single computer. Identifies threats, Do not prevent Threats.
- Network-based IDS (NIDS) monitors and evaluates network activity to detect attacks or event anomalies. Identifies threats, Do not prevent Threats.
- SIEM gathers log data from sources across an enterprise to understand security concerns and apportion resources. Identifies threats, Do not prevent Threats.

# Network-based IDS (NIDS)

- Network-based IDS focuses on network traffic
  - NIDS examine raw packets in the network passively and triggers alerts
- NIDS look for raw packets that indicate:
  - Denial-of-Service attacks
  - Port scans or sweeps
  - Malicious content in data payload
  - Vulnerability scanning
  - Trojans, viruses, or worms
  - Brute-force attacks

## Advantages:

Easy deployment

Unobtrusive

It takes fewer systems to provide IDS coverage

A network-based IDS has visibility into all network traffic and can correlate attacks among multiple systems

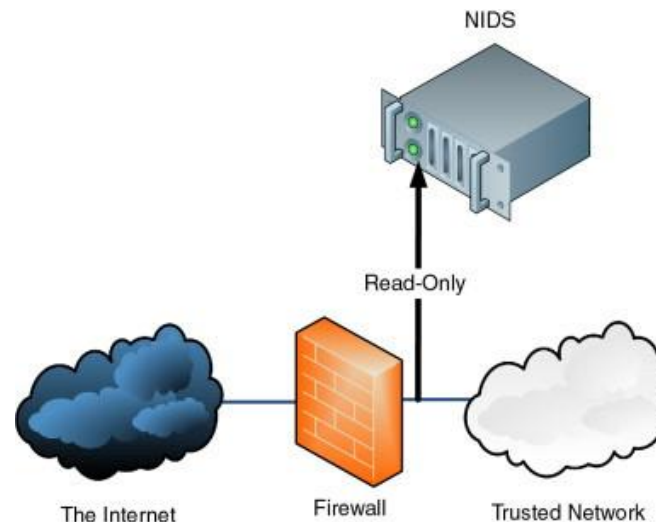
## Disadvantages:

It is ineffective when traffic is encrypted

It cannot see traffic that does not cross it

It must be able to handle high volumes of traffic

It does not know about activity on the hosts themselves





# Host-based IDS (HIDS)

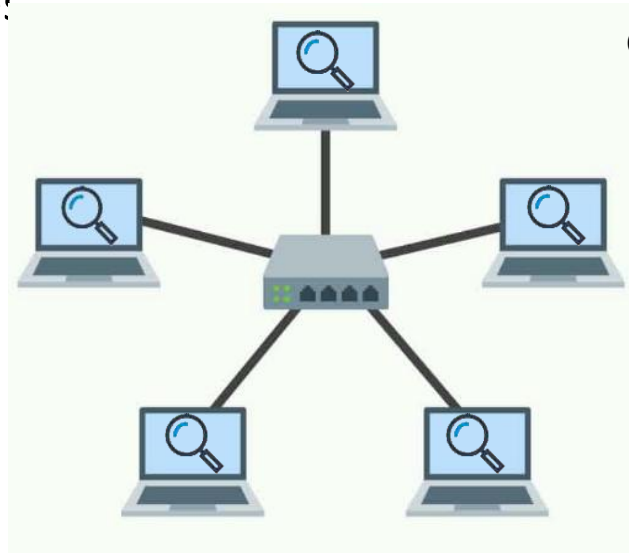
- Host-based IDS focuses on a single workstation
  - HIDS analyses audit-trails, logs, integrity of files and directories, etc.
- HIDS looks for hostile actions or misuse activities, such as:
  - Logins at odd hours
  - Login authentication failures
  - Adding new user accounts
  - Modification or access of critical system files
  - Modification or removal of binary files
  - Starting or stopping processes
  - Privilege escalation
  - Using certain programs

## Advantages:

- More accurate than NIDS
- Less volume of traffic so less overhead
- Examination of data after decryption
- Application specific

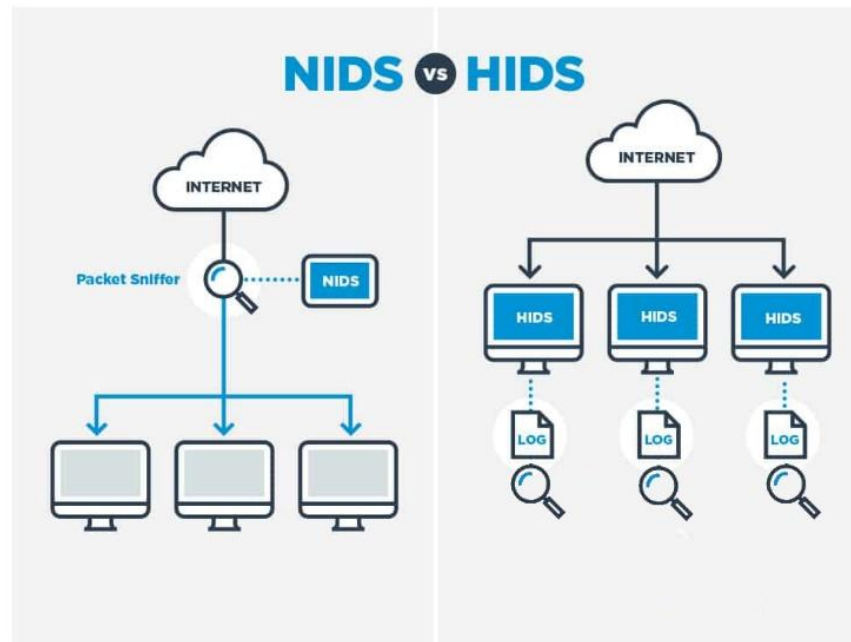
## Disadvantages:

- Has a process on every system watched, using up resources
- Has a high cost of ownership and deployment
- Has a focused view and cannot relate to activity around it
- A locally logged IDS may be compromised or disabled



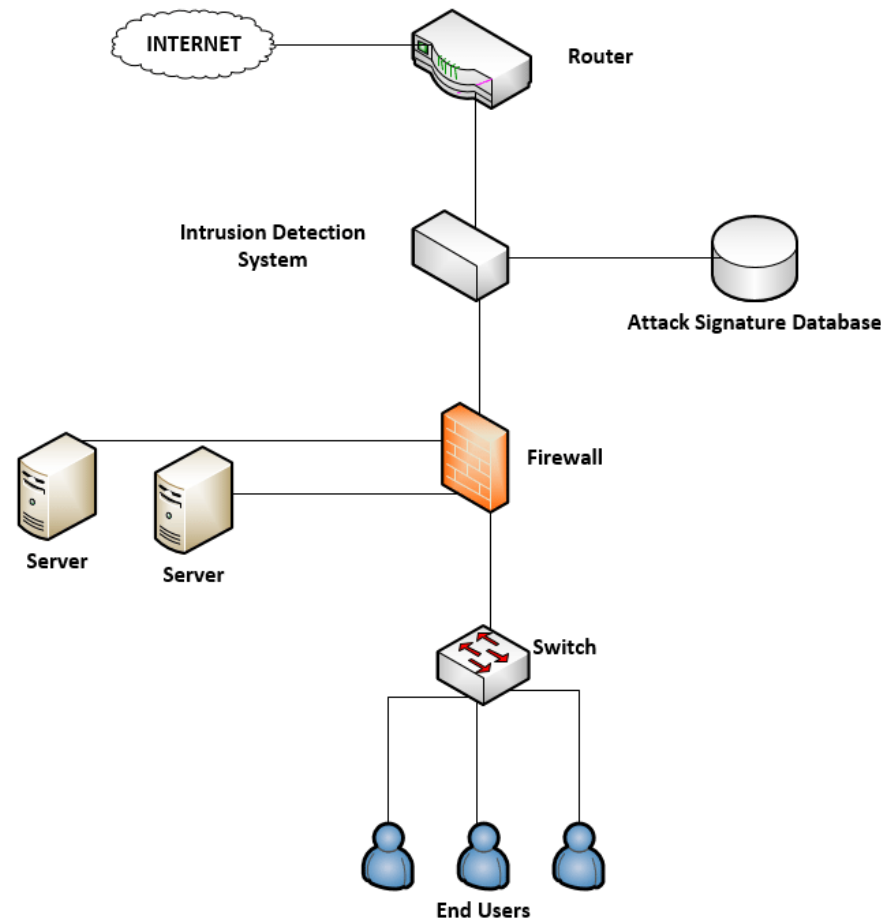
# Difference between NIDS and HIDS

- The main difference is **what is being monitored**
  - NIDS monitors network traffic in the network
  - HIDS monitors logs in the hosts



# Signature-based Detection

- Uses specifically known patterns to signify attack
  - These specific patterns are called signatures
- The IDS looks for activity that matches these signatures and if found, an alert is raised



## Advantages:

- Fairly fast
- Easy to implement
- Easy to update
- Very low false positive detection

## Disadvantages:

- Relies on a pre-defined signature database – any activity, malicious or otherwise, that the signature-based IDS does not have a signature for will go undetected.

# Anomaly-based Detection

- Uses statistical model or machine learning engine to characterise normal usage behaviours
- Anomaly detection algorithm:
  1. The IDS builds a profile of normal behaviour on the host or network being protected (i.e. baseline)
  2. Monitor subsequent activities and compare against baseline
  3. If usage deviates from normal behaviour, raise an alert
- Example:
  - A user normally logs on during office hours everyday (baseline)
  - If the user logs on at 2am, this is determined to deviate from baseline
  - Therefore, an alert is raised

## Advantages:

- Can detect attempts to exploit new and unforeseen vulnerabilities
- Can recognise authorised usage that falls outside the normal pattern

## Disadvantages:

- Generally slower, more resource intensive compared to signature-based IDS
- Greater complexity and difficult to configure
- Higher percentages of false positives/alerts

# Virtual Private Network (VPN)

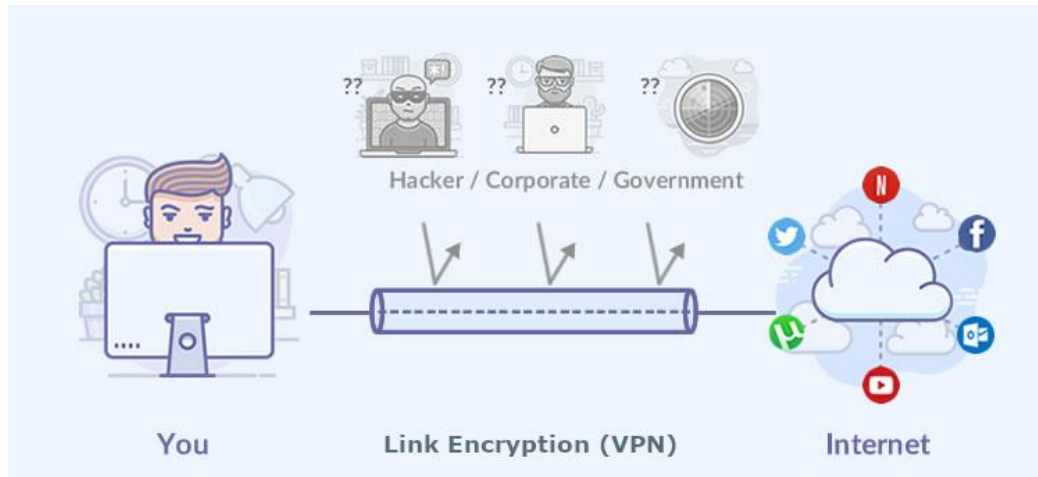
Part 4c



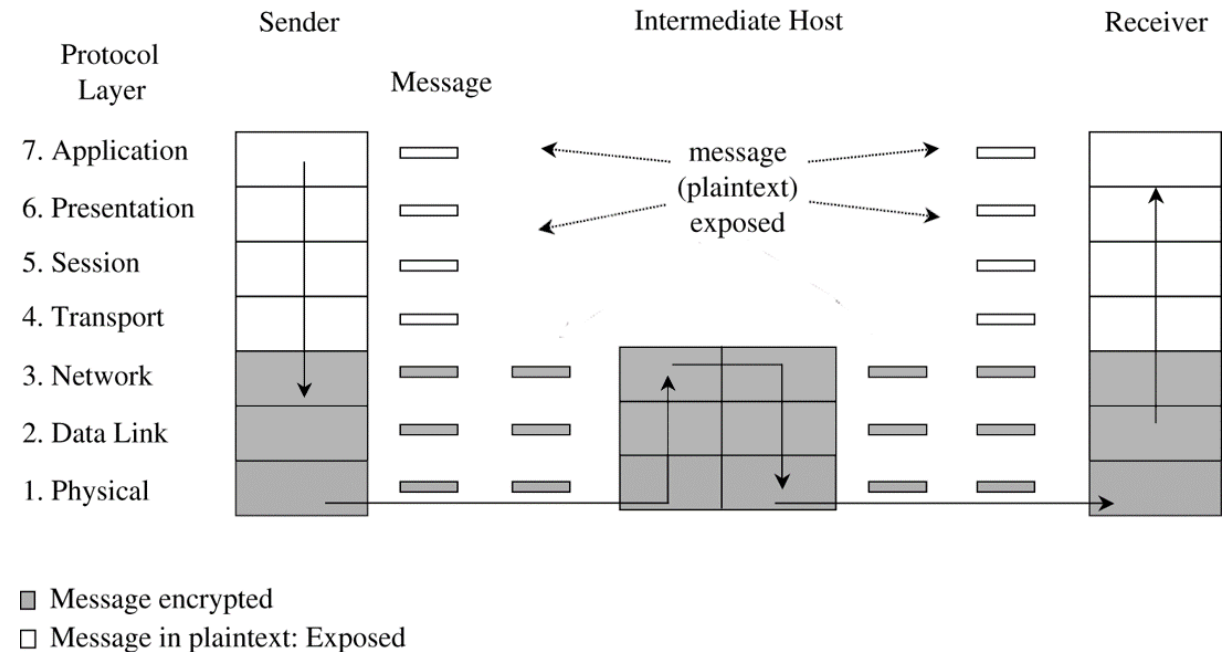
# Encryption for Networks

- In hosts, encryption is applied on data such as:
  - File
  - Text, audio, video
  - Database, hard disk
- In network applications, encryption can be applied either:
  - Between two hosts – **Link encryption**
  - Between two applications – **End-to-end encryption**

# Link Encryption



Data is encrypted while in transit to the destination, thus protecting the communication channel



Encryption only applies to lower layers

Message is encrypted **in transit** between two computers

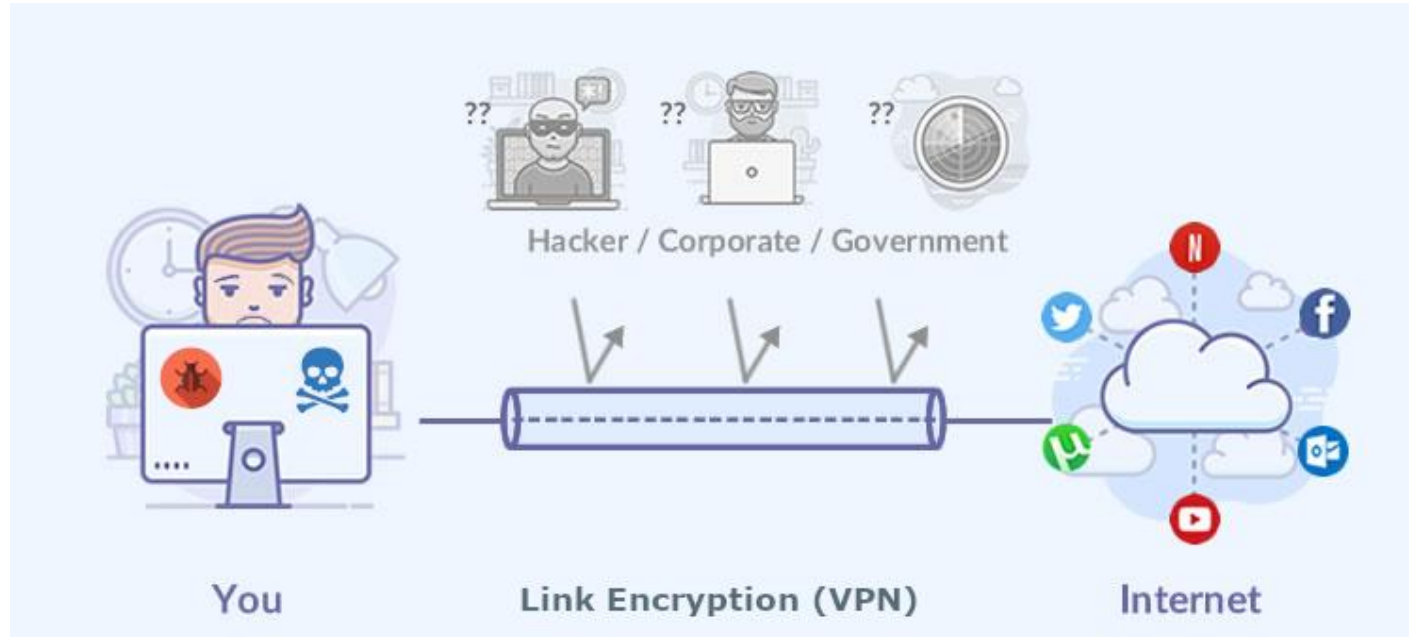
Message is **not encrypted** inside the computers



# Benefits of Link Encryption

- Users do not need to do anything to initiate it as it works at a lower layer in the OSI model
  - Transparent to all applications i.e. all network data will automatically be encrypted
- All network data is encrypted, including headers, addresses, and routing information

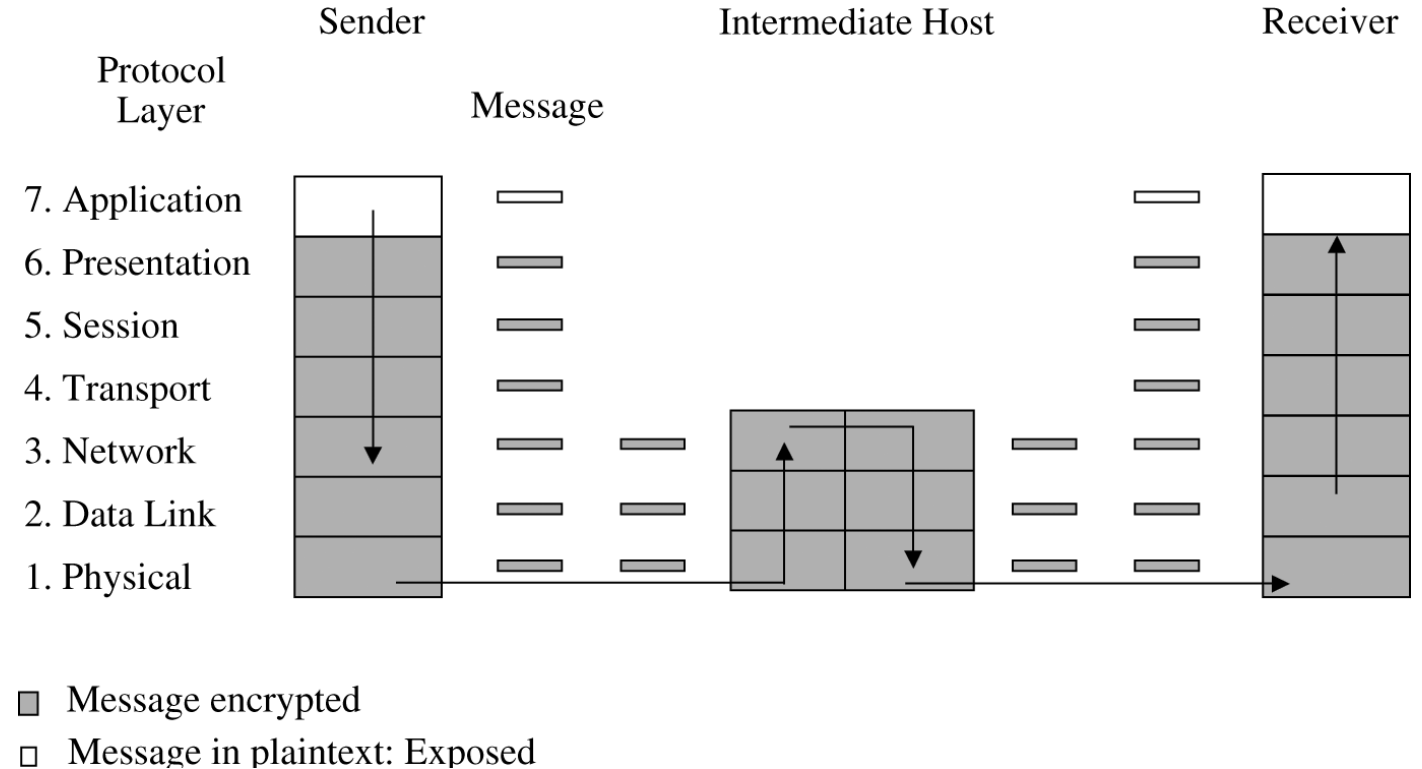
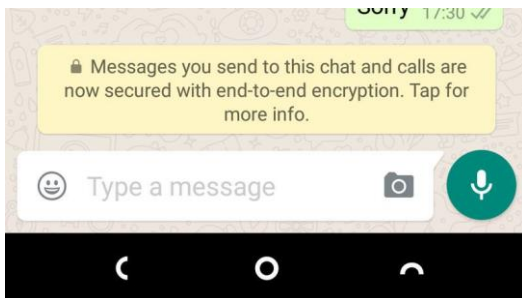
# Limitations of Link Encryption



- Since messages are not encrypted in hosts, malware or other applications can steal data from within the host itself

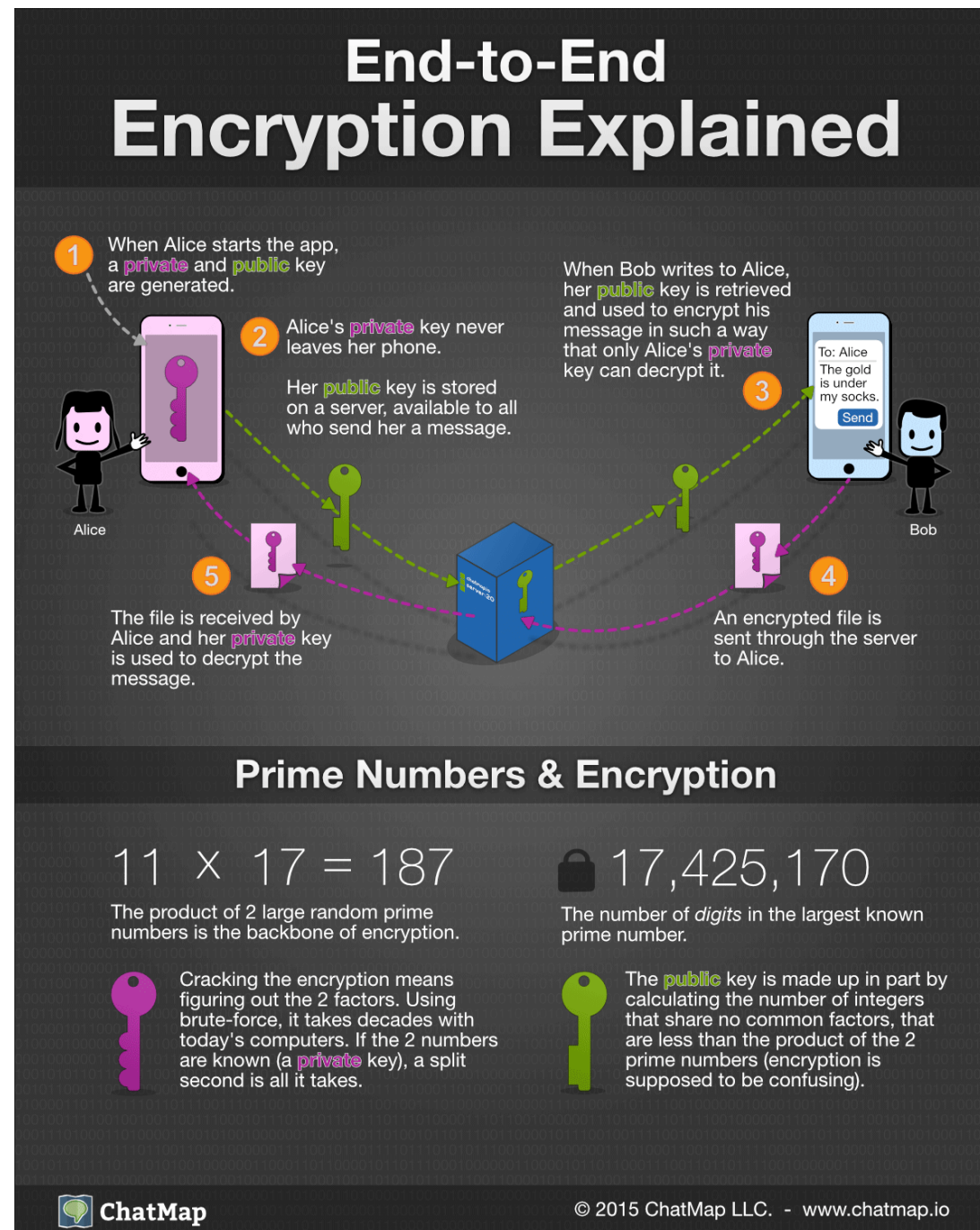
# End-to-End Encryption

- Provides encryption from application to application
  - Data is encrypted by the application (e.g. Whatsapp) before being transmitted
  - Even Operating System cannot access data



The encryption is performed at the highest levels (Layer 7 application or at Layer 6 presentation) of the OSI model

# End-to-End Encryption uses Asymmetric Encryption





# Benefits of End-to-End Encryption

- More secure but feature depends entirely on the application
  - Whatsapp has end-to-end encryption
  - WeChat does not have end-to-end encryption
  - Email “generally” does not have end-to-end encryption

# Difference between End-to-End and Link Encryption

Fig. 1a: Encryption in transit

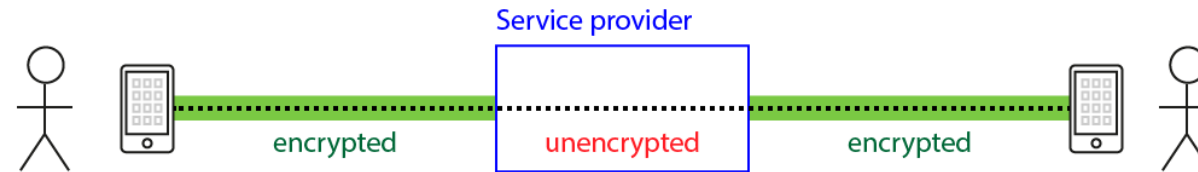


Fig. 1b: End-to-end encryption

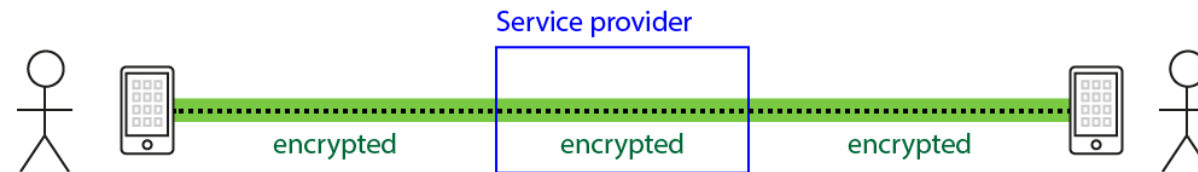


Fig. 1c: End-to-end encryption (no service provider)



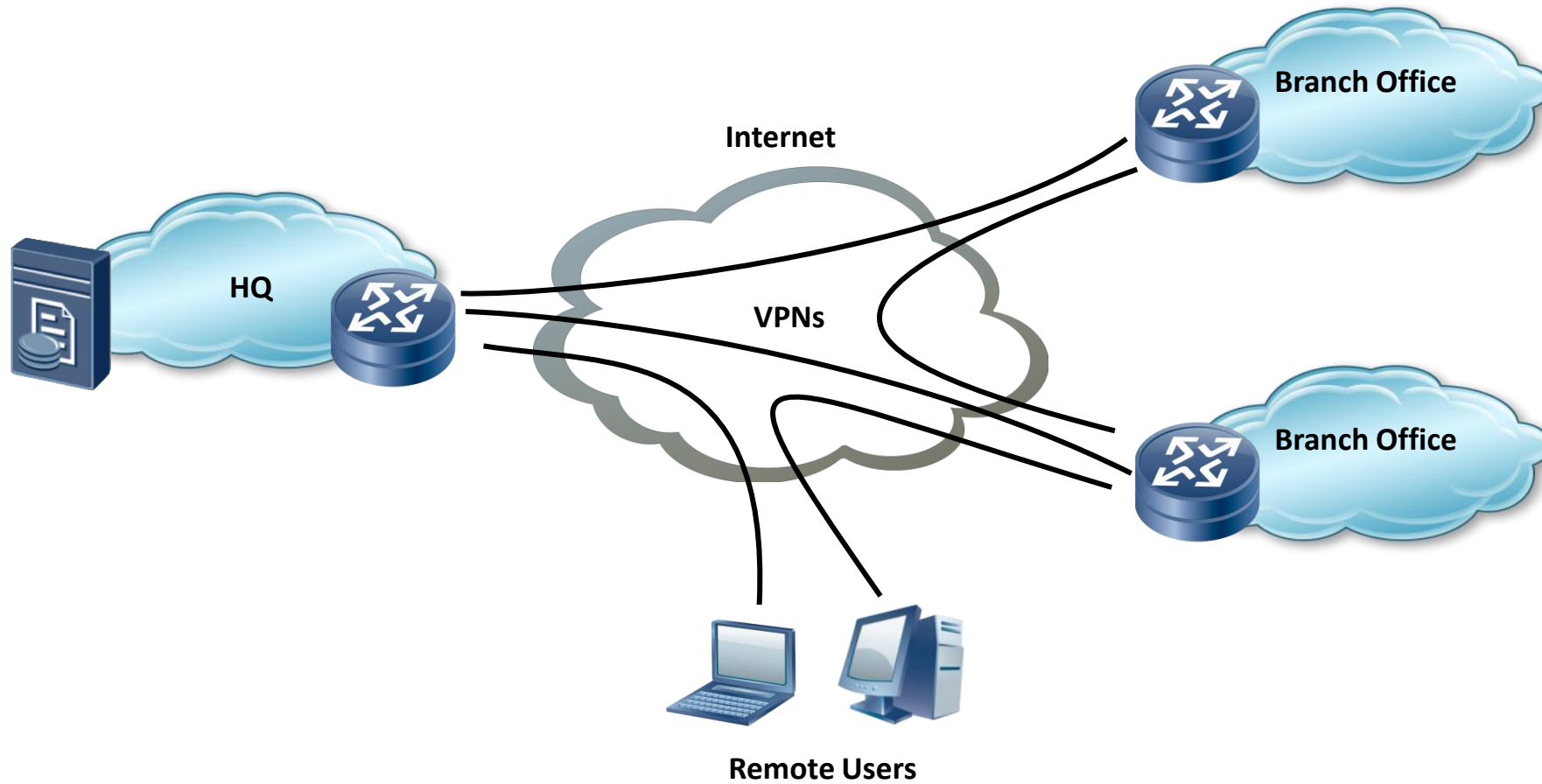
# VPN Overview

- Virtual Private Network (VPN) is a **link encryption** protocol
  - Creates encrypted links over public network

VPN is a framework that describes methods of creating a private network over a public network infrastructure

- VPN uses tunneling protocols to create **virtual point-to-point links** between two points over IP internetwork

# Virtual Links using VPN





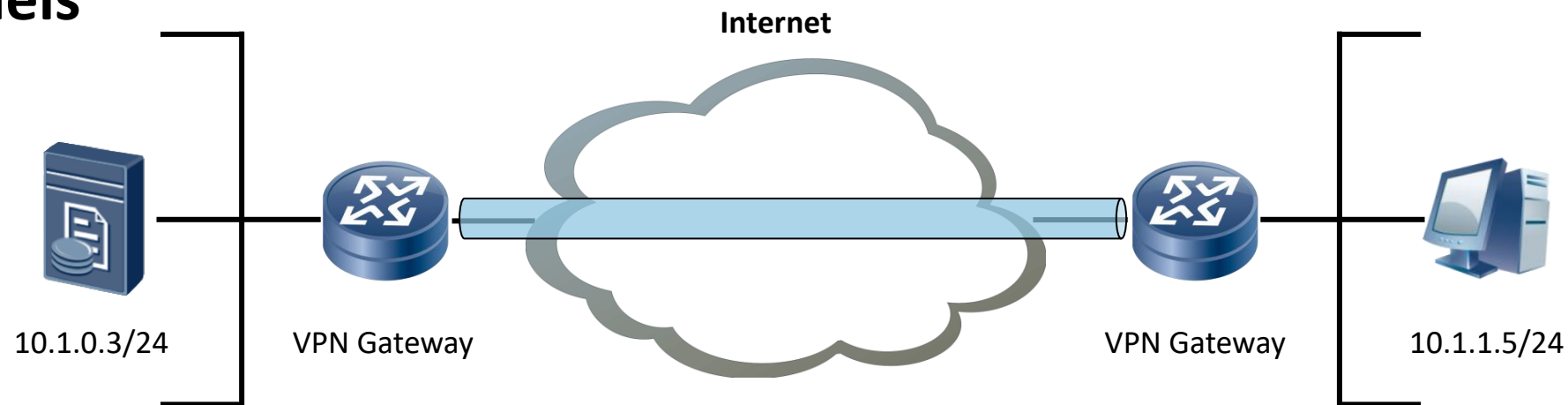
# Components Necessary for a VPN

- Existing computing and network infrastructure
  - Routers, switches, etc.
  - Servers, desktops, printers, etc.
- IP connection (e.g. Internet, LAN)
- **VPN gateways**
  - Special network devices that establishes and manages VPN tunnels;
  - Host-based VPN software that establishes VPN tunnels

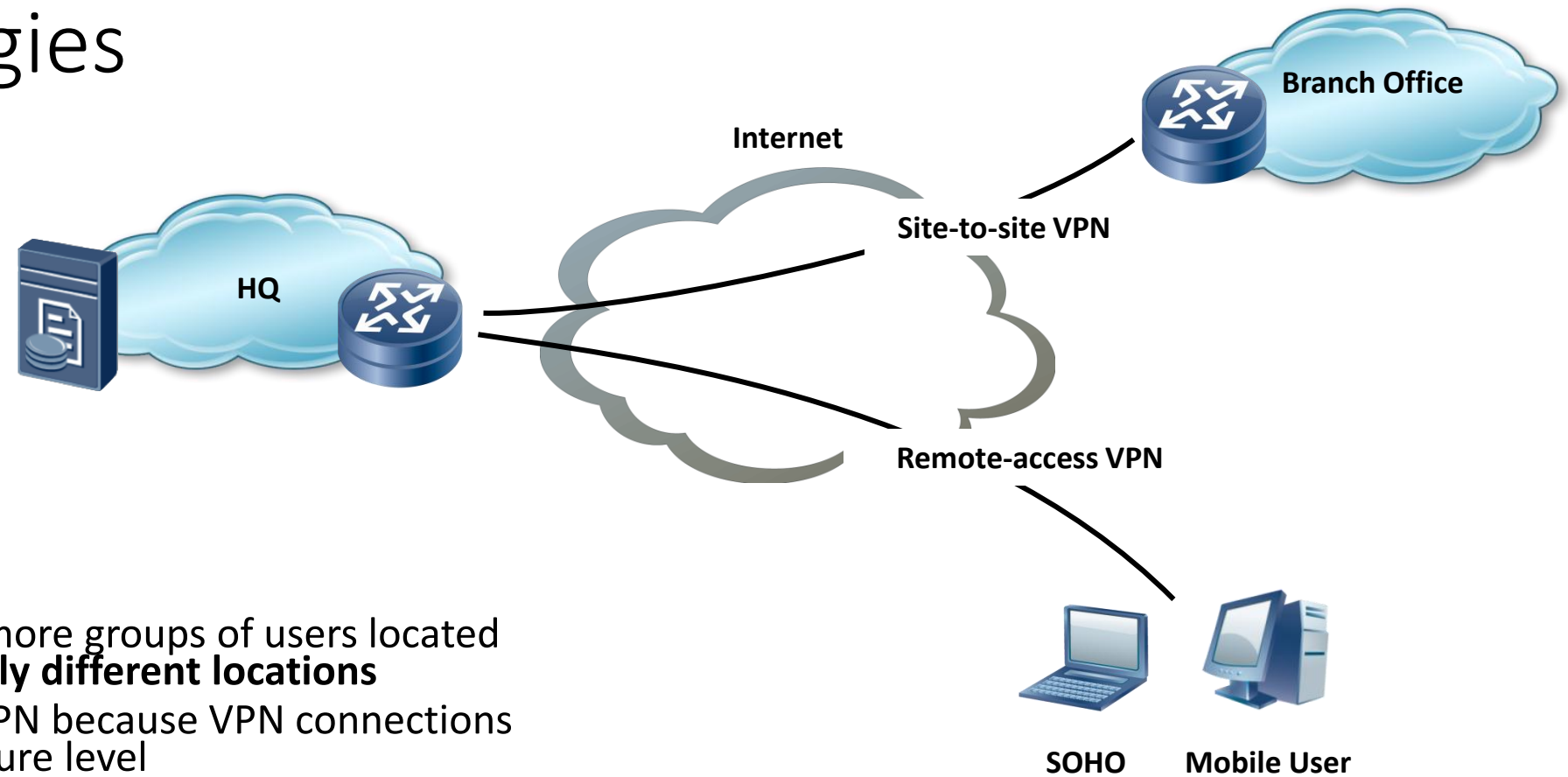


# Virtual Tunnels in VPN

- VPN gateway uses tunneling protocols (e.g. GRE, IPsec, MPLS) to create a “wormhole” through the Internet
- Confidentiality of VPN traffic is achieved by using **encrypted VPN tunnels**



# VPN Topologies



- **Site-to-site VPN**

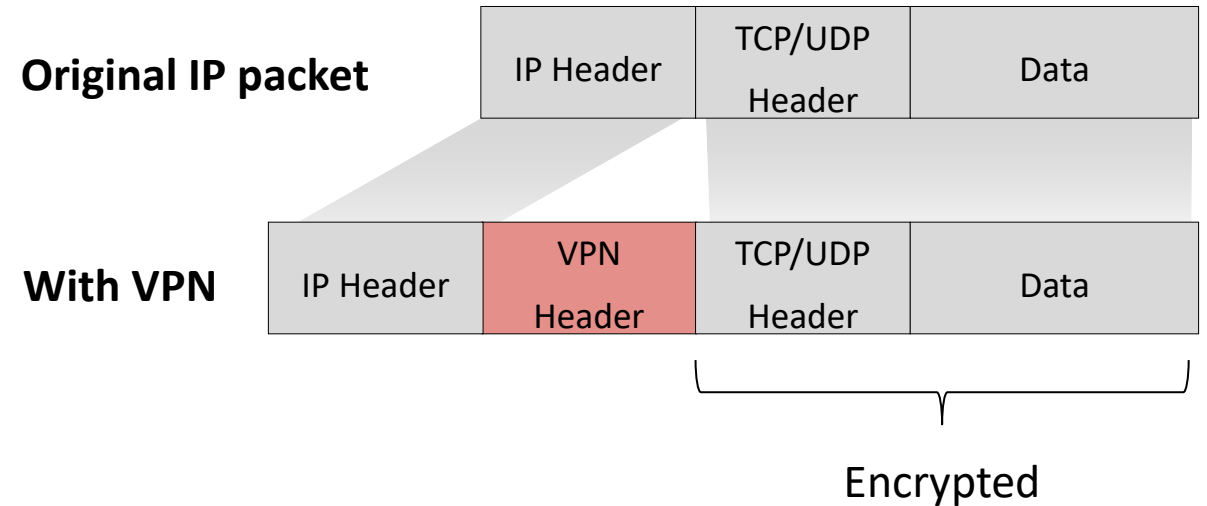
- Used to connect two or more groups of users located in **fixed but geographically different locations**
- Users are not aware of VPN because VPN connections established at infrastructure level

- **Remote-access VPN**

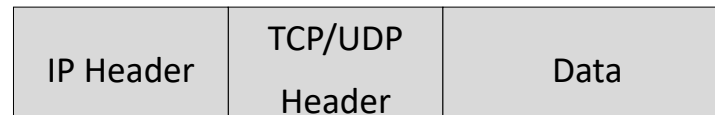
- Used by **individual users** who wish to gain access to company's intranet (e.g. Mobile users, telecommuters)
- Users will initiate the VPN connection when necessary

## Tunnel Mode

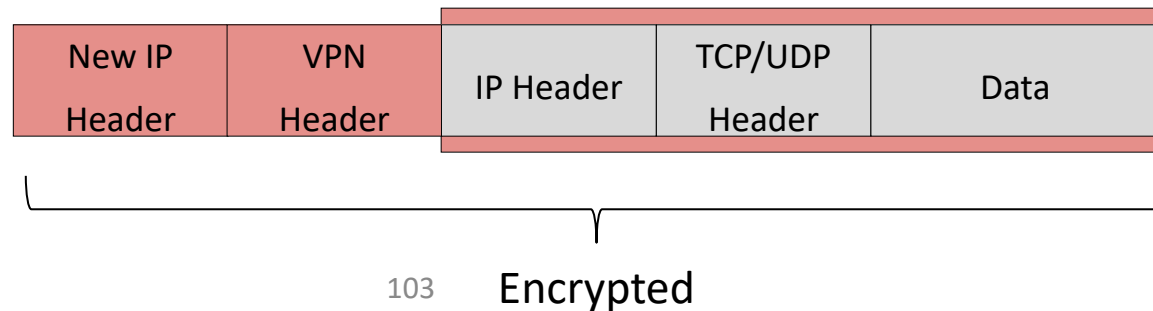
The entire IP packet is protected  
Original IP header is encapsulated inside  
another new IP packet  
Most commonly used mode. Normally  
used in gateway-to-gateway  
communications



## Original IP packet



## With VPN

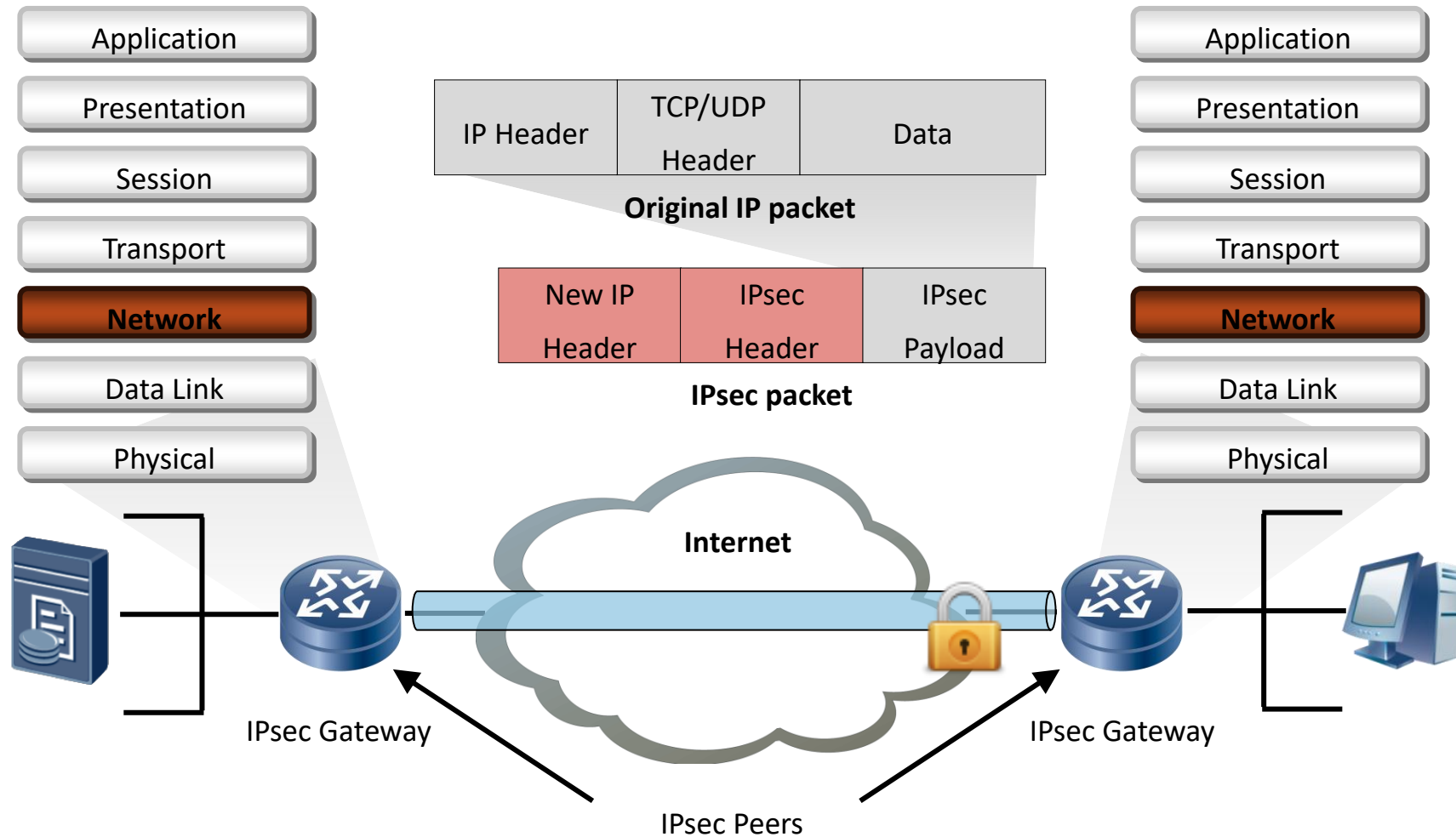


## Transport Mode

Only the payload of the  
original IP packet is protected  
The original IP header is  
unchanged  
Typically used in host-to-host  
communications

# Introducing IPsec

- Internet Protocol Security (IPsec) is a **suite of protocol** used for **secure communication over the IP network**
- IPsec is an **link security framework** that works at the Network Layer of the OSI Model





# Summary

1. Networking Fundamentals
2. Network Threats
  1. Passive Network Attacks
  2. Active Network Attacks
3. Mitigating Network Attacks
  1. Firewall
  2. Intrusion Detection System (IDS)
  3. Virtual Private Network (VPN)
  4. IPSec